

**Internal candidate artifact.** Not public, not final, not sealed, not live, not certification, not audit standard, not assurance opinion.

## INTERNAL CANDIDATE ARTIFACT

# Agentic AI Auditability & Assurance White Paper 2026

A Lifecycle Evidence Guide for Audit, Assurance, and Enterprise AI Governance

Trace Tag: WP2-2026-R4-PUBLICATION-CANDIDATE

Version: v0.1-publication-candidate

Author: Jearon Wong

Generated: 2026-05-17T15:45:27.756Z

This internal artifact is generated under the WP2 R4 package for candidate review only. It is not a public release, final seal, live deployment, audit standard, certification, legal compliance proof, assurance opinion, regulator approval, procurement recommendation, vendor ranking, Big Four endorsement, audit body endorsement, MPLP requirement, or external outcome claim.

---

## Relationship to the Agentic Lifecycle Governance Industry Series

The Agentic Lifecycle Governance Industry Series is fixed as a 3+3 structure: three core industry white papers and three practitioner guides. WP1 defines the compliance object layer for agentic lifecycle governance. WP2 defines the audit evidence object layer. Guide 1 will later translate WP2 into audit-ready technical implementation planning. Guide 2 will later translate WP1 and WP2 into compliance operating-model planning. WP3 will later address insurability. This R4 package prepares WP2 candidate source for review; it does not publish or replace those later assets.

---

## Executive Thesis

AI agent auditability cannot be built on logs alone. An agentic system becomes auditable only when its lifecycle work can be reconstructed through responsibility-linked evidence chains.

**Agentic AI Auditability** is the ability to reconstruct, test, and evidence agentic lifecycle work across authority, responsibility, tools, outcomes, exceptions, and remediation. This definition is

WP2 author synthesis grounded in audit evidence language, AI governance guidance, provenance/logging concepts, privacy/evidence-retention guidance, and GAIC's MRO object layer.

---

## Source Note

Big Four sources are used as market context only. Professional audit and assurance sources support terminology, evidence concepts, internal-control language, and assurance boundaries. AI governance/public guidance sources support governance context.

Evidence/provenance/observability/logging sources support the logs-versus-evidence distinction. Privacy sources support evidence minimization, selective disclosure, and retention tension. GAIC source truth supports MROs, Validation Lab boundaries, RCCS-M/ALCS context, and companion-paper boundaries. Inline source IDs in the candidate source map to `sources/wp2-r4-source-register.md` and `sources/wp2-r4-citation-map.md`.

---

## Boundary Note

This candidate source is not an audit standard, certification, legal compliance proof, assurance opinion, regulator-approved method, procurement recommendation, vendor ranking, Big Four endorsement, audit body endorsement, MPLP requirement, or MPLP industry-standard claim. AARM is a proposed readiness model, not a score, benchmark, certification, assurance result, or vendor assessment.

---

## Table of Contents

0. Executive Summary
1. Scope, Audience, and Non-Audit-Standard Boundary
2. Why AI Agent Auditability Is Different from Model Governance
3. The Audit Object Shift: From Model Output to Lifecycle Work
4. Why Logs Are Not Audit Evidence Chains
5. The Agentic Audit Object Model
6. MRO-to-Audit-Evidence Mapping
7. Evidence Request List for Agentic Systems
8. Lifecycle Walkthrough for AI Agent / MAS Work
9. Evidence Partitioning Across Agents, Tools, Roles, Vendors, and Projects
10. Privacy, Selective Disclosure, and Audit Evidence Minimization

- 11.Exception, Dispute, and Remediation Closure
- 12.Third-Party Validation Without Certification Claims
- 13.Agentive Auditability Readiness Model
- 14.Enterprise Implementation: CIO / CTO / CCO Readiness
- 15.How Audit and Assurance Firms Can Use This Framework
- 16.Conclusion

Appendix A. Agentive Audit Evidence Request List Appendix B. Agentive System Walkthrough Template Appendix C. MRO-to-Audit-Evidence Mapping Appendix D. Auditability Readiness Matrix Appendix E. Exception / Remediation Closure Checklist Appendix F. Boundary Language

---

## 0. Executive Summary

**Candidate source status:** R4 publication-candidate preparation source **Chapter purpose:** State the auditability problem, the object shift, the evidence-chain answer, the AARM bridge, and the non-standard boundary. **Reader question:** Why does agentive AI need a new auditability frame?

### Key Claims

- AI agent auditability cannot be built on logs alone.
- Agentive systems become auditable only when lifecycle work can be reconstructed through responsibility-linked evidence chains.
- Auditability shifts the review object from model output alone to lifecycle work across authority, responsibility, tools, outcomes, exceptions, privacy treatment, and remediation.
- GAIC MROs can be translated into audit evidence objects and evidence requests.
- AARM is a proposed readiness model for describing auditability readiness; it does not issue assurance, certification, or legal compliance proof.

### Source Grounding Note

Market context is grounded in BF-01, BF-02, and BF-05. Audit evidence language is grounded in AUD-01 and AUD-02. AI governance context is grounded in AI-01 and AI-08. Observability context is grounded in EVID-02. MROs, Validation Lab boundaries, and companion-paper boundaries are GAIC-derived source truth.

## Author Synthesis Note

Agentic AI Auditability, Agentic Audit Object, Audit Evidence Chain, lifecycle-responsibility-linked agent work, and AARM are WP2 author synthesis. They are not presented as externally issued audit standards or certification schemes.

## Candidate Prose

AI agent auditability cannot be built on logs alone. Logs matter. Traces matter. Workflow histories, tool-call records, telemetry, and incident records all help reconstruct technical activity. But agentic auditability asks a different question: not merely what happened inside a system, but whether the work can be reviewed as lifecycle responsibility.

The shift is subtle and material. Traditional AI governance often begins with the model, the dataset, the output, the control environment, and the policy framework. Those layers remain necessary.

An agentic system, however, does not only produce outputs. It delegates work, calls tools, transfers tasks across agents, accepts or disputes outcomes, escalates exceptions, stores evidence, crosses vendor or processor boundaries, and may require remediation. A log can record that a tool call occurred. By itself, it usually does not establish who authorized the action, which human role owned the work, whether the agent acted inside a delegated authority boundary, whether the outcome was accepted, what exception occurred, or whether remediation closed.

WP2 defines **Agentic AI Auditability** as the ability to reconstruct, test, and evidence agentic lifecycle work across authority, responsibility, tools, outcomes, exceptions, and remediation. This is an authored definition. It is grounded in professional audit evidence language, AI governance guidance, provenance concepts, observability/logging documentation, privacy guidance, and GAIC's existing lifecycle responsibility object layer.

It is not a legal definition, audit standard, assurance engagement requirement, certification criterion, or regulator-approved compliance test.

The central contribution of this paper is the Audit Evidence Object layer. WP1 defined Missing Regulatory Objects for agentic lifecycle governance. WP2 translates those objects into auditability terms: evidence requests, walkthrough structures, responsibility maps, evidence partitioning, privacy-aware disclosure, third-party review boundaries, and readiness levels.

The Agentic Audit Object is the unit of review. The Audit Evidence Chain is the responsibility-linked structure that connects lifecycle work to authority, role, tool action, evidence pointer, accepted outcome, exception state, and closure state.

This matters because audit and assurance readers increasingly face AI systems whose behavior cannot be understood through model cards, output samples, policy attestations, or raw telemetry alone. Big Four and professional sources already discuss AI assurance, trusted AI, responsible AI, audit transformation, governance, risk, controls, and agentic AI adoption. Those discussions create the market context for WP2.

WP2 does not claim that any firm endorses this framework. Instead, it offers an object-model layer adjacent to those discussions: a disciplined way to ask what must exist before agentic work can be reconstructed.

The paper's recurring distinction is simple:

- Logs record activity.
- Observability explains system behavior.
- Audit evidence supports responsibility review.
- Responsibility-linked evidence chains make agentic lifecycle work reconstructable.

The distinction does not make logs unimportant. Logs and traces are often evidence ingredients. They may identify time, sequence, tool, service, user, or execution path. But audit evidence requires more than event capture. It requires relevance, reliability, sufficiency in context, relationship to review objective, and linkage to responsibility. For agentic systems, that means linking activity to lifecycle work units, human roles, agent roles, delegated authority, accepted outcomes, exception handling, privacy treatment, and remediation closure.

WP2 also introduces the **Agentic Auditability Readiness Model (AARM)**. AARM describes whether an agentic system is unobservable, log-visible, trace-linked, evidence-structured, auditability-ready, or assurance-ready for planning purposes. AARM is deliberately bounded. It is not a score, benchmark, certification, audit opinion, assurance conclusion, legal compliance proof, regulator approval, procurement recommendation, or vendor ranking. Its purpose is to help organizations and reviewers discuss readiness before they overstate assurance.

For enterprises, WP2 prepares the path to two practitioner guides. Guide 1 will translate auditability into technical architecture for CIO, CTO, platform, security, and engineering teams. Guide 2 will translate auditability into compliance operating-model design for CCO, governance,

legal, risk, internal audit, and policy-to-evidence teams. WP2 defines what audit-ready means; the later guides will address how to build and govern toward it.

For audit and assurance firms, WP2 can be used as a discussion and readiness structure. It can support evidence request framing, walkthrough scoping, object-model review, and internal method conversations. It does not replace professional methodology, professional judgment, engagement acceptance, independence rules, attestation criteria, assurance standards, or audit procedures. The paper is useful only if its boundary is kept visible.

## Executive Orientation Table

| WP2 element             | What it means                                                                                                                                    | Source / synthesis status                                                                        | Boundary                                              |
|-------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------|-------------------------------------------------------|
| Agentic AI Auditability | Ability to reconstruct, test, and evidence agentic lifecycle work across authority, responsibility, tools, outcomes, exceptions, and remediation | WP2 author synthesis grounded by AUD-01, AUD-02, AI-01, AI-08, EVID-01, EVID-02, and GAIC-SOURCE | Not audit standard, legal proof, or assurance opinion |
| Agentic Audit Object    | Reviewable lifecycle work object for agentic systems                                                                                             | WP2 author synthesis derived from GAIC MROs and provenance/audit evidence concepts               | Not mandatory schema                                  |
| Audit Evidence Chain    | Responsibility-linked chain connecting work unit, authority, role, tool, evidence, outcome, exception, privacy treatment, and closure            | WP2 author synthesis                                                                             | Not a certification criterion                         |
| MRO-to-evidence mapping | Translation of GAIC MROs into audit evidence objects and evidence requests                                                                       | GAIC-derived plus audit/control language                                                         | MROs are not legal mandates                           |
| AARM                    | Proposed readiness model for                                                                                                                     | WP2 author synthesis                                                                             | Not score,                                            |

| WP2 element | What it means | Source / synthesis status                       | Boundary                           |
|-------------|---------------|-------------------------------------------------|------------------------------------|
|             | auditability  | grounded by R4B/R1 and audit/governance sources | certification, or assurance result |

## Cross-Links

- See Appendix A for evidence request categories.
- See Appendix C for the full MRO-to-audit-evidence mapping.
- See Appendix D for the AARM readiness matrix.
- See Appendix F for boundary language.

## Boundary Note

This chapter does not claim WP2 is published, final, sealed, regulator-approved, audit-body-endorsed, Big-Four-endorsed, legally sufficient, certifying, or assurance-producing.

---

## 1. Scope, Audience, and Non-Audit-Standard Boundary

**Candidate source status:** R4 publication-candidate preparation source **Chapter purpose:**

Define who WP2 is for, what it does, what it does not do, how sources are used, and how GAIC/MPLP/Validation Lab relate to the draft. **Reader question:** Who should use this paper, and what authority must it not claim?

## Key Claims

- WP2 is a lifecycle evidence guide and auditability readiness framework.
- WP2 is not an audit standard, assurance opinion, certification, legal compliance proof, regulator approval, procurement recommendation, vendor ranking, or Big Four/audit body endorsement.
- Big Four sources are market context only.
- GAIC is the source for MROs, AARM planning, Validation Lab boundary, and companion-paper scope.
- MPLP may be discussed as one optional lifecycle protocol path, never as required or industry-standard.

## **Source Grounding Note**

Assurance and attestation boundaries use AUD-03 and BOUND-03. Certification and conformity-assessment boundaries use BOUND-01 and BOUND-02. Governance role context uses AUD-07. Big Four AI assurance context uses BF-02 and BF-03 only as market context.

## **Author Synthesis Note**

WP2's scope, Audit Evidence Object layer, Agentic Audit Object, Audit Evidence Chain, and AARM are author synthesis. They are draft framework constructs, not externally adopted professional requirements.

## **Candidate Prose**

This paper is written for readers who need to understand whether agentic AI work can be reconstructed. Its primary audience includes audit and assurance professionals, internal audit teams, technology risk teams, AI governance committees, enterprise control owners, CIOs, CTOs, CCOs, CROs, legal/privacy stakeholders, and platform leaders responsible for agentic systems. Its secondary audience includes advisory teams, AI assurance practitioners, risk engineering teams, agent runtime builders, procurement and vendor-risk teams, and standards or policy readers exploring agentic AI governance.

The paper's scope is deliberately narrow. It does not try to restate all model governance, responsible AI, cybersecurity, privacy, or enterprise risk management. Those fields remain necessary. WP2 focuses on the lifecycle evidence layer that becomes necessary when AI systems act through agents, tools, memory, delegation, multi-agent handoffs, and remediation workflows. The question is not simply whether a model behaved acceptably. The question is whether the lifecycle work can be reconstructed across authority, responsibility, tools, outcomes, exceptions, and closure.

WP2 is best understood as a lifecycle evidence guide. It defines the proposed object layer needed for audit-ready agentic work, maps GAIC MROs into audit evidence objects, proposes evidence request categories, provides walkthrough and partitioning patterns, introduces AARM readiness levels, and preserves boundaries around privacy, third-party validation, and assurance. It is a draft architecture for auditability, not a professional standard.

The source hierarchy matters. Professional audit and assurance sources provide language for evidence, controls, assurance boundaries, internal audit, attestation, and professional limits. AI governance sources provide context for risk management, accountability, monitoring,



documentation, and human oversight. Evidence, provenance, observability, and log-management sources help distinguish raw event data from responsibility-linked evidence. Privacy sources ground the tension between reviewability, minimization, selective disclosure, and retention. Big Four sources provide market context: they show that AI assurance, trusted AI, audit transformation, and agentic AI are active enterprise topics. They do not endorse this paper.

GAIC source truth plays a different role. WP1 created the MRO object layer and the broader Agentic Lifecycle Governance framing. WP2 uses those GAIC-derived objects as its internal foundation. When this paper discusses MRO-01 through MRO-16, RCCS-M/ALCS context, the Evidence-Based Validation Pattern, Validation Lab boundary language, or companion-paper sequencing, it is relying on GAIC source truth, not external audit standards.

MPLP should be handled with care. MPLP may be described as one protocol path whose lifecycle responsibility semantics can help express evidence objects. WP2 does not require MPLP, does not rank MPLP above other approaches, does not claim MPLP is an industry standard, and does not claim MPLP proves compliance, auditability, assurance readiness, or enterprise readiness. Guide 1 may later discuss implementation paths, but WP2 must remain implementation-neutral.

Validation Lab is also boundary-sensitive. GAIC describes Validation Lab as a non-certifying evidence adjudication example. WP2 may use that boundary as an example of third-party evidence review without certification. It must not describe Validation Lab as a certification body, conformity assessment body, regulator, audit firm, assurance provider, legal authority, or proof of compliance.

The safest reading of WP2 is this: it provides a structured way to ask what evidence must exist before agentic AI work can be meaningfully reviewed. It does not determine whether that evidence is sufficient for a particular audit, assurance engagement, legal analysis, regulatory process, insurance underwriting decision, procurement decision, or board conclusion. Those determinations belong to qualified professionals operating under their own methods, scopes, independence requirements, criteria, and legal obligations.

## Scope Table

| Area             | WP2 does                                                            | WP2 does not do                                               | Source / boundary grounding     |
|------------------|---------------------------------------------------------------------|---------------------------------------------------------------|---------------------------------|
| Auditability     | Defines proposed lifecycle evidence objects and readiness questions | Issue audit opinions or audit procedures                      | AUD-01, AUD-02, AUD-03          |
| Assurance        | Frames readiness for possible assurance planning                    | Provide assurance conclusion or engagement standard           | AUD-03, BOUND-03                |
| Certification    | Distinguishes validation from certification                         | Certify systems or define certification criteria              | BOUND-01, BOUND-02              |
| Legal/privacy    | Frames evidence/privacy tension                                     | Provide legal advice or legal compliance proof                | PRIV-01 to PRIV-05, AI-09       |
| Big Four context | Uses public materials as market context                             | Claim endorsement, adoption, or need                          | BF-01 to BF-05                  |
| GAIC/MRO         | Uses MROs as GAIC-derived object layer                              | Claim MROs are law or external standards                      | GAIC-SOURCE                     |
| MPLP             | Treats MPLP as optional protocol path                               | Require MPLP or claim industry-standard status                | GAIC-SOURCE                     |
| Validation Lab   | Gives non-certifying evidence adjudication example                  | Claim certification, assurance opinion, or regulator approval | GAIC-SOURCE, BOUND-01, BOUND-02 |

## Cross-Links

- Appendix F contains reusable boundary language.
- Chapter 12 expands the validation/certification boundary.
- Chapter 15 addresses professional use by audit and assurance firms.

## Boundary Note

This chapter intentionally repeats non-claim language because WP2's usefulness depends on not overstating its authority.

---

## 2. Why AI Agent Auditability Is Different from Model Governance

**Candidate source status:** R4 publication-candidate preparation source **Chapter purpose:** Explain why model governance is necessary but insufficient for agentic auditability. **Reader question:** What changes when AI systems act through agents, tools, memory, delegation, and multi-agent workflows?

### Key Claims

- Model governance remains necessary for agentic systems, but it does not fully reconstruct lifecycle work.
- Agentic AI introduces delegated authority, tool action, role separation, handoffs, accepted outcomes, exception states, and remediation closure.
- Auditability must therefore move beyond model/output review into lifecycle responsibility review.

### Source Grounding Note

Big Four market context appears in BF-01, BF-04, and BF-05. AI governance context appears in AI-01, AI-02, AI-04, AI-05, and AI-08. Internal audit context appears in AUD-06. GAIC source truth provides MRO and RCCS-M/ALCS lifecycle-object context.

### Author Synthesis Note

The claim that "model governance is necessary but insufficient" for agentic auditability is WP2 author synthesis grounded in the shift from model/output governance to lifecycle responsibility objects.

### Candidate Prose

Model governance is not obsolete. It remains part of responsible AI practice. Organizations still need to understand model purpose, data, evaluation, limitations, monitoring, robustness, bias, security, human oversight, and change management. Public AI governance frameworks and

professional guidance continue to provide important language for risk management, accountability, documentation, monitoring, controls, and internal audit review.

The limitation is not that model governance is wrong. The limitation is that agentic systems create work that is not reducible to model behavior. An agent may plan a sequence, invoke a tool, pass work to another agent, store state, retrieve memory, request human confirmation, act under delegated authority, trigger an external workflow, or remediate an exception. A model output may be only one event in a broader lifecycle.

For auditability, that broader lifecycle matters. If an agent drafts a message, the model output may be reviewed. If an agent sends the message through a CRM tool, updates a customer record, triggers a refund, routes a contract, or changes a production configuration, the relevant review object is no longer only the output. It is the work unit: who initiated it, what authority permitted it, what agent and tool executed it, what evidence was retained, who accepted the result, what exception occurred, and how any remediation closed.

This creates an object gap. Traditional governance may document the model, evaluate outputs, approve use cases, and monitor performance. Agentic auditability must also document authority boundaries, role mappings, tool-action evidence, responsibility transfer, evidence partitioning, privacy treatment, and closure. These are lifecycle objects, not merely model attributes.

The distinction becomes clearer when human oversight is considered. A human-in-the-loop control may be meaningful only if the loop is tied to an identifiable responsibility state. Who was the human? What role did they occupy? What were they asked to confirm? Was the confirmation advisory, blocking, or final? Was it tied to the delegated authority boundary? Did it create an accepted outcome state? Did it leave evidence that another reviewer can reconstruct? Without these objects, "human oversight" may be real operationally but weak evidentially.

Agentic systems also complicate responsibility because agent roles are not human roles. Human-like names, personas, and task labels may help interfaces, but they can blur governance. An "analyst agent" is not the same thing as an analyst. It is a bounded execution role with tool permissions, instructions, constraints, evidence obligations, and escalation paths. A human or organizational role still owns intent, authority, acceptance, and remediation.

The point of WP2 is to place model governance beside lifecycle evidence architecture. Model governance asks whether the model and its use are governed. Agentic auditability asks whether the agentic work can be reconstructed. Both are needed. The second cannot be inferred from

the first.

**Table 1: Traditional AI Audit vs Agentic AI Auditability**

| Traditional AI audit focus | Agentic auditability focus         | Missing lifecycle object     | Evidence needed                                                     | Source / synthesis note                         | Boundary                                      |
|----------------------------|------------------------------------|------------------------------|---------------------------------------------------------------------|-------------------------------------------------|-----------------------------------------------|
| Model documentation        | Lifecycle work reconstruction      | Agentic Audit Object         | Work unit ID, scope, evidence chain, accepted outcome               | Mixed: AI-01, AI-08, GAIC-SOURCE, WP2 synthesis | Not a new audit standard                      |
| Output review              | Accepted outcome review            | Accepted outcome state       | Reviewer role, acceptance/rejection/dispute state, evidence pointer | GAIC-derived + AUD-01/AUD-06                    | Acceptance is not legal proof                 |
| Monitoring                 | Authority and exception monitoring | Authority drift record       | Baseline authority, observed action, escalation, closure evidence   | AI-02, EVID-04, GAIC-SOURCE                     | Drift is not automatically a legal breach     |
| Access control             | Delegated authority review         | Delegated authority boundary | Scope, condition, expiry, tool action, escalation                   | AI-08, AUD-06, GAIC-SOURCE                      | IAM permission is not full business authority |

| Traditional AI<br>audit focus | Agentic<br>auditability<br>focus           | Missing<br>lifecycle<br>object              | Evidence<br>needed                                                    | Source /<br>synthesis note    | Boundary                                        |
|-------------------------------|--------------------------------------------|---------------------------------------------|-----------------------------------------------------------------------|-------------------------------|-------------------------------------------------|
|                               |                                            |                                             | Human role,<br>agent role,<br>tool record,<br>partitioned<br>evidence | AUD-04,<br>AUD-05,<br>EVID-01 | Walkthrough is<br>not formal audit<br>procedure |
| Control testing               | Lifecycle<br>responsibility<br>walkthrough | Responsibility<br>map and<br>evidence chain |                                                                       |                               |                                                 |

**Table note:** Mixed source-grounded, GAIC-derived, and WP2 author-synthesis table. It is not a certification table, audit procedure, procurement tool, or vendor comparison.

Cross-Links

- Chapter 3 defines the audit object shift.
- Chapter 5 defines the Agentic Audit Object Model.
- Appendix C maps MROs to audit evidence objects.

Boundary Note

This chapter does not attack model governance or claim model governance is useless. It argues that agentic auditability requires an additional lifecycle responsibility layer.

3. The Audit Object Shift: From Model Output to Lifecycle Work

**Candidate source status:** R4 publication-candidate preparation source **Chapter purpose:** Define the proposed review object for agentic auditability. **Reader question:** What exactly should audit stakeholders reconstruct?

Key Claims

- Agentic auditability requires a shift from model/output review to lifecycle work review.
- The Agentic Audit Object is a proposed review object for lifecycle-responsibility-linked agent work.
- Lifecycle-responsibility-linked agent work connects intent, authority, role, agent action, tool action, evidence, outcome, exception, privacy treatment, and closure.

## Source Grounding Note

Audit evidence language is grounded in AUD-01 and AUD-02. Governance context is grounded in AI-01 and AI-08. Provenance concepts are grounded in EVID-01. MRO source truth is GAIC-derived.

## Author Synthesis Note

Agentic Audit Object and lifecycle-responsibility-linked agent work are WP2 author-synthesis constructs. They are not claimed as existing professional standards, legal categories, or regulator-defined objects.

## Candidate Prose

An audit object is the thing being reviewed. In many AI governance conversations, the object is a model, dataset, output, use case, control, system, or policy. Those objects remain important. But agentic systems create another review object: lifecycle work.

Lifecycle work is not a single output. It is the chain of actions and decisions by which an agentic system receives intent, acts under authority, uses tools, transfers work, records evidence, produces a result, reaches acceptance or dispute, handles exceptions, and closes remediation. If that chain cannot be reconstructed, the system may be observable but not audit-ready.

WP2 calls the proposed review unit the **Agentic Audit Object**. It is a structured representation of lifecycle-responsibility-linked agent work. It is not a mandatory data schema. It is a conceptual object model that helps audit, assurance, governance, and technology teams ask whether the relevant lifecycle work can be reviewed.

The Agentic Audit Object exists because agentic systems blur the boundary between process and output. A model-generated draft may be an output. A tool action that sends the draft, records the transaction, updates a system, triggers a workflow, or changes a downstream state is lifecycle work. The auditability question changes from "Was the output acceptable?" to "Can the lifecycle work that produced and accepted that outcome be reconstructed?"

The object shift also changes the meaning of responsibility. Responsibility cannot be inferred from a username, service account, model name, trace ID, or tool log alone. A responsibility-linked review object should identify the human role responsible for intent, authority, review, acceptance, exception handling, and remediation. It should separately identify the agent role and tool surface that executed the work. It should preserve the difference between technical

execution and business responsibility.

Provenance concepts help explain why this structure matters. Provenance language distinguishes entities, activities, agents, and relationships. Audit evidence language asks whether evidence is relevant and reliable for the review objective. WP2 combines those ideas with GAIC's MRO layer: lifecycle work must be addressable, linked, partitioned, and reviewable.

The Agentic Audit Object therefore contains more than a log. It contains the work unit, the authority boundary, the human role, the agent role, the tool-action record, the evidence pointer, the accepted outcome state, the exception state, the remediation closure state, and the privacy/selective disclosure profile. Those fields may live in different systems. The model is not saying every enterprise must store them in one database. It says that the relationships must be reconstructable.

This object shift is also where WP2 becomes distinct from WP1. WP1 identifies the missing regulatory objects for agentic lifecycle governance. WP2 asks how those objects become evidence. The same MRO can be read as a governance gap, an engineering object, or an audit evidence object. WP2 focuses on the third reading.

### Agentic Audit Object Overview

| Object component          | Review question                                   | Evidence examples                                     | Source / synthesis status                         | Boundary                       |
|---------------------------|---------------------------------------------------|-------------------------------------------------------|---------------------------------------------------|--------------------------------|
| Lifecycle work unit       | What work is under review?                        | Work unit ID, scope, task intent, lifecycle stage     | WP2 synthesis grounded by EVID-01 and GAIC-SOURCE | Not mandatory schema           |
| Authority boundary        | Was the action authorized within scope?           | Delegation record, condition, expiry, escalation path | GAIC-derived + AI-01/AI-08                        | Not proof of legal delegation  |
| Human role responsibility | Who owned intent, review, acceptance, or closure? | Role map, review record, acceptance owner             | GAIC-derived + AUD-06/AUD-07                      | Not legal liability assignment |
| Agent role responsibility | What agent role executed or                       | Agent role ID, constraints,                           | WP2/GAIC synthesis + EVID-01                      | Agent is not a                 |



| Object component                | Review question                                             | Evidence examples                                                   | Source / synthesis status      | Boundary                       |
|---------------------------------|-------------------------------------------------------------|---------------------------------------------------------------------|--------------------------------|--------------------------------|
| surface                         | transformed the work?                                       | capability<br>boundary                                              |                                | legal person                   |
| Tool-action evidence            | What external or consequential action occurred?             | Tool call record, affected system, reversibility, rollback evidence | GAIC-derived + EVID-02/EVID-03 | Not legal liability conclusion |
| Accepted outcome                | Was the result accepted, disputed, rejected, or remediated? | Acceptance state, reviewer role, dispute reason                     | GAIC-derived + AUD-01/AUD-04   | Not compliance proof           |
| Exception / remediation closure | How was deviation handled and closed?                       | Exception record, corrective action, recheck, closure owner         | GAIC-derived + EVID-04/AUD-04  | Not legal settlement           |

**Table note:** Mixed GAIC-derived and WP2 author-synthesis table grounded in audit evidence, provenance, and governance sources. It is not an audit standard or legal template.

## Cross-Links

- Chapter 5 expands the object model fields.
- Chapter 6 maps each MRO into audit evidence objects.
- Appendix B provides a walkthrough template.

## Boundary Note

The Agentic Audit Object is a proposed WP2 object model for reviewability. It does not create legal categories, professional requirements, certification criteria, or mandatory implementation schema.

---

## 4. Why Logs Are Not Audit Evidence Chains

**Candidate source status:** R4 publication-candidate preparation source **Chapter purpose:**

Ground the core WP2 claim that logs and traces are useful but insufficient for agentic auditability. **Reader question:** What can logs show, and what do they fail to prove?

### Key Claims

- Logs, traces, metrics, and workflow histories can support auditability.
- They do not automatically prove authority, responsibility, accepted outcome, exception handling, privacy treatment, or remediation closure.
- Audit Evidence Chains increase evidentiary value by linking activity to lifecycle responsibility metadata.

### Source Grounding Note

Audit evidence language is grounded in AUD-01 and AUD-02. Observability and logging context is grounded in EVID-02 and EVID-03. Provenance concepts are grounded in EVID-01.

Incident/governance context is grounded in EVID-04. AI Act logging context may be referenced as legal context only through AI-06.

### Author Synthesis Note

"Logs are not audit evidence chains" is WP2 author synthesis. It is grounded in the distinction between observability/logging and professional audit evidence concepts.

### Candidate Prose

Logs are necessary but not sufficient. That sentence is the safest starting point for agentic auditability. The point is not to diminish logs, traces, metrics, monitoring systems, workflow histories, or observability platforms. They are often the first evidence ingredients available. Without them, reconstruction may collapse into narrative memory.

The problem is that logs usually describe activity, not responsibility. A log may show that a service called a tool at a time. A trace may show that a workflow crossed several components. A metric may show latency, error rate, or throughput. An incident record may show that something failed. Those are useful signals. They do not automatically tell a reviewer whether the action was authorized, which human role owned it, which agent role was acting, what business scope applied, whether the tool action was reversible, whether the outcome was accepted, what privacy treatment applied, or whether remediation closed.

Audit evidence is tied to a review objective. In professional audit language, evidence is evaluated for relevance and reliability within context. For agentic systems, the review objective is not merely to explain system behavior. It is to reconstruct lifecycle responsibility. That means the evidence must connect the technical event to authority, role, tool action, outcome state, exception state, privacy treatment, and closure.

Observability explains how systems behave. Auditability asks whether lifecycle work can be reviewed. The same trace can be valuable for both, but it plays different roles. In observability, the trace helps engineers understand execution path and performance. In auditability, the trace is an input to a larger evidence chain. It must be joined with responsibility records, authority records, evidence pointers, acceptance records, and exception/remediation records.

Consider a tool call. A log may show the tool name, timestamp, endpoint, response code, and service identity. The auditability question is broader: Who authorized the tool action? Was the agent operating inside delegated scope? Which data or system was affected? Was the action reversible? Did a human review occur before or after the action? Was the result accepted, disputed, or remediated? Was sensitive data minimized or redacted in review evidence? Was there a closure state?

The same distinction applies to incident records. An incident log may show that an error occurred. It may not show whether the affected outcome was withdrawn, corrected, re-reviewed, accepted, escalated, or closed. It may not show whether the issue was due to authority drift, responsibility transfer, cross-project reuse, tool-action side effects, privacy leakage, or vendor/runtime substitution. Without linkage to lifecycle objects, the incident is visible but not fully reconstructable.

WP2 calls the needed structure an **Audit Evidence Chain**. An Audit Evidence Chain is not just a sequence of logs. It is a responsibility-linked reconstruction path. It ties a lifecycle work unit to the relevant evidence objects: authority boundary, human role, agent role, tool action, evidence pointer, accepted outcome, exception, remediation, privacy treatment, and third-party review boundary where relevant.

This structure also protects against over-retention. A naive response to auditability gaps is to collect everything. That can create privacy and confidentiality risks. A better approach is to preserve evidence pointers, partition keys, disclosure profiles, redaction rules, retention logic, and integrity records so reviewers can reconstruct what they are authorized to inspect without unnecessary exposure.

**Table 2: Logs vs Audit Evidence Chains**

| Evidence item  | What logs/traces can show                    | What they do not automatically prove                             | Required linkage                                                                | Related MRO            | Source / synthesis note         |
|----------------|----------------------------------------------|------------------------------------------------------------------|---------------------------------------------------------------------------------|------------------------|---------------------------------|
| Tool-call log  | Tool, endpoint, timestamp, service, response | Business authority, human owner, reversibility, accepted outcome | Delegated authority record, human role map, tool-action evidence, outcome state | MRO-02, MRO-05, MRO-04 | EVID-02/EVID-03 + GAIC-SOURCE   |
| Trace span     | Execution path, service dependencies, timing | Lifecycle responsibility or review sufficiency                   | Work unit ID, agent role, evidence pointer, role map                            | MRO-01, MRO-03, MRO-08 | EVID-01/EVID-02 + WP2 synthesis |
| Workflow state | Step completion, state transition            | Whether state is a governance acceptance state                   | Acceptance criteria, reviewer role, dispute/remediation state                   | MRO-04, MRO-16         | AUD-01/AUD-04 + GAIC-SOURCE     |
| Incident log   | Error event, detection, response action      | Remediation closure or legal fault                               | Exception owner, corrective action, recheck, closure acceptance                 | MRO-07, MRO-16         | EVID-04/AUD-04                  |
| Access log     | User/service access event                    | Delegated business authority or scope                            | Authority boundary, confirmation rule, risk class,                              | MRO-02, MRO-07         | AI-01/AI-08 + WP2 synthesis     |

| Evidence item | What logs/traces can show               | What they do not automatically prove               | Required linkage                                                  | Related MRO            | Source / synthesis note |
|---------------|-----------------------------------------|----------------------------------------------------|-------------------------------------------------------------------|------------------------|-------------------------|
|               |                                         |                                                    | expiry                                                            |                        |                         |
|               |                                         |                                                    | Privacy                                                           |                        |                         |
| Retention log | Data/evidence storage or deletion event | Whether retention/disclosure is legally sufficient | treatment, minimization rule, retention basis, disclosure profile | MRO-10, MRO-12, MRO-13 | PRIV-01 to PRIV-05      |

**Table note:** Mixed source-grounded and author-synthesis table. Logs are treated as useful inputs, not as useless artifacts. The table is not a vendor critique or audit procedure.

## Cross-Links

- Appendix A lists evidence request categories.
- Chapter 9 addresses evidence partitioning.
- Chapter 10 addresses minimization and selective disclosure.

## Boundary Note

This chapter does not claim observability vendors fail, logs are useless, or telemetry can never support audit evidence. It claims only that raw logs do not automatically become responsibility-linked audit evidence chains.

# 5. The Agentic Audit Object Model

**Candidate source status:** R4 publication-candidate preparation source **Chapter purpose:** Define the proposed object model for audit-ready agentic lifecycle work. **Reader question:** What makes lifecycle work audit-ready?

## Key Claims

- Audit-ready agentic lifecycle work should be addressable, reconstructable, partitioned,

privacy-aware, and reviewable.

- The Agentic Audit Object Model binds lifecycle work unit, authority boundary, human role responsibility, agent role responsibility, tool-action evidence, evidence pointer, accepted outcome, exception state, remediation closure, and privacy treatment.
- The model is a proposed review architecture, not a mandatory schema or standard.

### **Source Grounding Note**

The model uses audit evidence language from AUD-01, control vocabulary from AUD-04, AI governance context from AI-01, and provenance structure from EVID-01. MRO dependencies are GAIC-derived.

### **Author Synthesis Note**

The Agentic Audit Object Model is WP2 author synthesis. It is a conceptual object model for auditability, not a required implementation format.

### **Candidate Prose**

The Agentic Audit Object Model translates lifecycle work into a reviewable structure. It does not require that every enterprise use the same database table, evidence pack format, or protocol. It asks whether the relationships needed for review can be reconstructed.

The first requirement is an addressable lifecycle work unit. A reviewer needs to know what work is under review: the task, workflow, agent run, delegated action, tool call, handoff, or remediation event. Without a stable work unit, evidence remains scattered across logs, tickets, approvals, messages, policies, and memories.

The second requirement is an authority boundary. Agentic systems often combine technical permission with business action. Technical permission answers whether a service can call a tool. Business authority answers whether that action was allowed under scope, condition, risk class, and responsibility. Auditability requires evidence of the authority boundary, not merely evidence that the tool call succeeded.

The third requirement is role mapping. Human role responsibility and agent role responsibility surface must be separated. The human role owns intent, approval, review, acceptance, escalation, or closure. The agent role describes bounded execution capability, constraints, tool access, and evidence obligations. Confusing these roles weakens accountability and makes review harder.

The fourth requirement is tool-action evidence. A tool action is often where AI-generated output becomes operational consequence. The evidence object should identify the tool, action, target system, affected data or process, initiator, authority basis, reversibility, rollback path, and owner. This does not assign legal liability. It creates reviewability.

The fifth requirement is an evidence pointer. Auditability does not always require raw evidence to be duplicated into a central repository. It may require pointers to evidence, integrity hashes, redaction profiles, retention rules, and partition keys. The pointer must be strong enough that authorized reviewers can reconstruct the chain.

The sixth requirement is an accepted outcome state. An output is not the same as an accepted outcome. The model should distinguish produced, reviewed, accepted, rejected, disputed, remediated, and closed states. This is especially important when a downstream process treats agent work as completed before a responsible human or governance workflow has accepted it.

The seventh requirement is exception and remediation closure. Auditability is weak if exceptions disappear into operational tickets without lifecycle linkage. Exceptions should connect to authority, role, affected outcome, corrective action, recheck, closure owner, and reopen criteria.

The eighth requirement is privacy treatment. Evidence is not improved by unlimited collection. Reviewability must be balanced with minimization, selective disclosure, redaction, retention, and access control. The object model should identify which evidence can be disclosed, to whom, for what review purpose, and under what boundary.

Taken together, these fields create the Audit Evidence Chain. The chain does not replace professional judgment about sufficiency. It makes judgment possible by giving reviewers a reconstructable path.

**Agentic Audit Object Model Table**

| Field                  | Purpose                     | Example evidence                    | Related MRO | Source / synthesis status         | Boundary             |
|------------------------|-----------------------------|-------------------------------------|-------------|-----------------------------------|----------------------|
| Lifecycle work unit ID | Names the work under review | Workflow/run/task ID, scope, intent | MRO-08      | WP2 synthesis grounded in EVID-01 | Not mandatory schema |

| Field                             | Purpose                            | Example evidence                                              | Related MRO    | Source / synthesis status      | Boundary                       |
|-----------------------------------|------------------------------------|---------------------------------------------------------------|----------------|--------------------------------|--------------------------------|
| Authority boundary                | Records delegated scope and limits | Delegation record, condition, expiry, escalation rule         | MRO-02, MRO-07 | GAIC-derived + AI-01/AI-08     | Not legal delegation proof     |
| Human role responsibility         | Maps human ownership               | Intent owner, review owner, acceptance owner, closure owner   | MRO-01         | GAIC-derived + AUD-06/AUD-07   | Not legal liability assignment |
| Agent role responsibility surface | Defines bounded agent function     | Agent role, constraints, capability boundary, evidence duties | MRO-03, MRO-06 | WP2/GAIC synthesis + EVID-01   | Agent is not human role        |
| Tool-action evidence              | Records consequential action       | Tool ID, target system, affected data, rollback path          | MRO-05         | GAIC-derived + EVID-02/EVID-03 | Not liability conclusion       |
| Evidence pointer                  | Links to review evidence           | URI, hash, evidence pack reference, partition key             | MRO-08, MRO-12 | Mixed                          | Not blanket disclosure         |
| Accepted outcome                  | Records outcome governance state   | Accepted/rejected/disputed/remediated                         | MRO-04         | GAIC-derived + AUD-01/AUD-04   | Not compliance proof           |



| Field               | Purpose                               | Example evidence                                              | Related MRO      | Source / synthesis status     | Boundary                            |
|---------------------|---------------------------------------|---------------------------------------------------------------|------------------|-------------------------------|-------------------------------------|
|                     |                                       | status                                                        |                  |                               |                                     |
| Exception state     | Records deviation or dispute          | Exception ID, trigger, owner, escalation path                 | MRO-07, MRO-16   | GAIC-derived + EVID-04        | Not legal breach finding            |
| Remediation closure | Records corrective action and closure | Corrective action, recheck, closure reviewer, reopen criteria | MRO-16           | GAIC-derived + AUD-04/AUD-05  | Not settlement or regulator closure |
| Privacy treatment   | Defines minimization and disclosure   | Redaction profile, retention rule, access scope               | MRO-10 to MRO-13 | PRIV sources + GAIC synthesis | Not legal advice                    |

**Table note:** This table is mixed source-grounded, GAIC-derived, and author-synthesis. It is a drafting model, not an audit standard, certification checklist, or legal template.

## Cross-Links

- Chapter 6 maps the model to all MROs.
- Appendix A converts fields into evidence requests.
- Appendix B turns fields into a walkthrough template.

## Boundary Note

The Agentic Audit Object Model should be read as a review architecture. It does not require MPLP, Cognitive OS, Validation Lab, or any particular vendor system.

## 6. MRO-to-Audit-Evidence Mapping

**Candidate source status:** R4 publication-candidate preparation source **Chapter purpose:**

Translate GAIC MROs into audit evidence objects and evidence requests. **Reader question:**

How does each MRO become evidence?

## **Key Claims**

- GAIC MROs can be mapped into reviewable audit evidence objects.
- The mapping turns lifecycle governance objects into evidence request categories.
- MROs remain GAIC-derived governance objects; they are not legal mandates, audit standards, or certification criteria.

## **Source Grounding Note**

MRO names and meanings use GAIC source truth. Audit evidence language uses AUD-01. AI audit/control context uses AUD-05 and AI-01.

## **Author Synthesis Note**

The MRO-to-audit-evidence mapping is WP2 author synthesis derived from GAIC objects and externally sourced audit/control terminology.

## **Candidate Prose**

WP1 introduced the sixteen Missing Regulatory Objects for agentic and multi-agent system governance. WP2 reads those objects through an auditability lens. Each MRO asks a governance question. WP2 adds the evidence question: what object would a reviewer need to inspect to reconstruct the lifecycle work?

This translation is not a claim that MROs are law. It is not a claim that the presence of an MRO proves compliance. It is not a claim that absence proves non-compliance. MROs are GAIC-derived lifecycle responsibility objects. Their value for WP2 is that they give auditability a vocabulary for the work that logs alone do not capture.

The mapping also prevents a common failure in agentic governance: treating "evidence" as a flat export. Agentic systems do not need a pile of logs; they need evidence structured around review questions. Who owned the action? What authority applied? Which agent role acted? What tool created consequence? Was the outcome accepted? What exception occurred? What data was exposed? What changed after vendor, model, or runtime substitution? How did remediation close?

The sixteen MROs can be grouped into six auditability clusters:

1. Responsibility and role mapping: MRO-01, MRO-03, MRO-06.
2. Authority and action boundaries: MRO-02, MRO-05, MRO-07.
3. Outcome and closure: MRO-04, MRO-16.
4. Evidence partitioning and reuse: MRO-08, MRO-09.
5. Privacy and disclosure: MRO-10, MRO-11, MRO-12, MRO-13.
6. Vendor, processor, and substitution chains: MRO-14, MRO-15.

This cluster view helps readers see that auditability is not one control. It is the ability to reconstruct a lifecycle. A work unit can fail auditability at many points: no role map, no authority record, no accepted outcome state, no evidence partition, no privacy treatment, no substitution record, or no remediation closure.

**Table 3: MRO-to-Audit-Evidence Mapping**

| MRO                                             | Audit evidence object         | Sample evidence request                                                        | Source support              | Guide 1 relation                 | Guide 2 relation              | Bo      |
|-------------------------------------------------|-------------------------------|--------------------------------------------------------------------------------|-----------------------------|----------------------------------|-------------------------------|---------|
|                                                 |                               | Show accountable                                                               |                             |                                  |                               |         |
| MRO-01 Human Role to MAS Responsibility Mapping | Human-role responsibility map | role for intent, authorization, review, acceptance, exception, and remediation | AUD-06, AUD-07, AI-01       | Role/evidence architecture       | Responsibility governance     | No ass  |
|                                                 |                               | Show scope, condition,                                                         |                             |                                  |                               |         |
| MRO-02 Delegated Authority Boundary             | Delegated authority record    | expiry, escalation, and reauthorization evidence                               | AI-01, AI-06, AI-08, AUD-06 | Authority control implementation | Delegation policy-to-evidence | Not per |
| MRO-03 Agent Role is not Human Role             | Agent role boundary object    | Show agent role, capability limits,                                            | AI-08, EVID-01              | Agent role design                | Accountability model          | Do ant  |

| MRO                                          | Audit evidence object          | Sample evidence request                                                                                | Source support                                         | Guide 1 relation      | Guide 2 relation              | Bo          |
|----------------------------------------------|--------------------------------|--------------------------------------------------------------------------------------------------------|--------------------------------------------------------|-----------------------|-------------------------------|-------------|
|                                              |                                | constraints, owner, and escalation boundary                                                            | , AI-01                                                |                       |                               | age         |
| MRO-04 Accepted Outcome Compliance           | Accepted outcome record        | Show acceptance criteria, reviewer, acceptance/rejection/dispute state, and evidence link              | AUD-01, AUD-02, AUD-04                                 | Outcome state capture | Review/ acceptance governance | Acco<br>con |
| MRO-05 Tool-Action Liability Boundary        | Tool-action evidence object    | Show tool identity, action, affected system/data, authority basis, reversibility, rollback path, owner | EVID-02<br>,<br>EVID-03<br>,<br>EVID-04<br>,<br>AUD-05 | Tool evidence capture | Tool-action approval policy   | No<br>con   |
| MRO-06 Responsibility Transfer Across Agents | Responsibility transfer record | Show source/target agent, transferred scope, retained scope, inherited constraints,                    | EVID-01<br>, AI-08, AUD-06                             | Handoff record design | Transfer governance           | Not         |

| MRO                                     | Audit evidence object             | Sample evidence request                                                                       | Source support                    | Guide 1 relation                   | Guide 2 relation           | Bo        |
|-----------------------------------------|-----------------------------------|-----------------------------------------------------------------------------------------------|-----------------------------------|------------------------------------|----------------------------|-----------|
|                                         |                                   | acceptance/rejection                                                                          |                                   |                                    |                            |           |
| MRO-07 Authority Drift                  | Authority drift exception record  | Show baseline authority, observed action, trigger, escalation, stop/downgrade/reauthorization | AI-01, AI-02, EVID-04, AUD-04     | Drift monitoring                   | Exception governance       | Not leg   |
| MRO-08 MAS Evidence Partitioning        | Partitioned evidence chain        | Show partition keys, evidence pointers, link identifiers, integrity hashes, access rules      | EVID-01, EVID-02, EVID-03, AUD-01 | Evidence partitioning architecture | Evidence access governance | No rete e |
| MRO-09 Cross-Project Reuse Compliance   | Reuse context validation record   | Show source context, target context, reset validation, privacy review, authorization refresh  | AI-01, AI-05, PRIV-02, AUD-04     | Reuse validation workflow          | Reuse governance           | No clea   |
| MRO-10 Privacy / GDPR Lifecycle Mapping | Privacy lifecycle evidence object | Show data flow, processing purpose,                                                           | PRIV-01 to PRIV-05                | Privacy-aware evidence capture     | Privacy governance         | No GD     |

| MRO                                                   | Audit evidence object                            | Sample evidence request                                                                     | Source support                                 | Guide 1 relation            | Guide 2 relation              | Boundaries |
|-------------------------------------------------------|--------------------------------------------------|---------------------------------------------------------------------------------------------|------------------------------------------------|-----------------------------|-------------------------------|------------|
|                                                       |                                                  | retention rule, rights workflow, minimization treatment                                     | , AI-09                                        |                             |                               |            |
| MRO-11 Privacy-Preserving Third-Party Validation      | Validation disclosure profile and verdict record | Show ruleset identity, redaction profile, evidence pointer, verdict hash, reviewer boundary | PRIV-02 , PRIV-03 , BOUND-01, BOUND-02, AUD-03 | Evidence export/replay      | Third-party review governance | No claim   |
| MRO-12 Evidence Minimization and Selective Disclosure | Evidence minimization and disclosure object      | Show minimization rule, disclosure justification, redaction profile, access log, expiry     | PRIV-01 to PRIV-05                             | Selective disclosure design | Disclosure policy             | No con     |
| MRO-13 Data Subject Rights vs Evidence Retention      | Rights-retention reconciliation record           | Show request type, retention basis, hold status, deletion/redaction action, owner           | PRIV-01 , PRIV-02 , PRIV-05 , AI-09            | Rights-aware retention      | Legal/privacy governance      | Rec rev    |

| MRO                                                      | Audit evidence object                  | Sample evidence request                                                                               | Source support                         | Guide 1 relation              | Guide 2 relation     | Bo         |
|----------------------------------------------------------|----------------------------------------|-------------------------------------------------------------------------------------------------------|----------------------------------------|-------------------------------|----------------------|------------|
| MRO-14 Third-Party Processor / Subprocessor Chain        | Processor/ subprocessor chain evidence | Show processor role, subprocessor chain, data agreement pointer, responsibility owner                 | AI-09, PRIV-01, PRIV-02, AUD-04        | Vendor evidence partitioning  | Processor governance | No         |
| MRO-15 Vendor / Model / Runtime Substitution Conformance | Substitution conformance record        | Show prior/new component, control evidence, evidence-integrity check, reauthorization, revalidation   | AI-01, AI-04, AI-05, AUD-04, BOUND-02  | Runtime/model change evidence | Change governance    | No cer     |
| MRO-16 Incident, Dispute, and Remediation Closure        | Incident/ remediation closure record   | Show event, affected outcome, owner, corrective action, recheck, closure acceptance, reopen condition | EVID-04, AI-02, AUD-04, AUD-05, AUD-06 | Remediation workflow evidence | Closure governance   | No reg acc |

**Table note:** GAIC-derived and author-synthesis mapping grounded in audit/control/governance

source language. It is not a legal checklist, audit procedure, certification criterion, or procurement tool.

## Cross-Links

- Appendix C contains the expanded mapping.
- Chapter 13 maps the same objects into AARM dimensions.
- Guide 1 will later translate this table into implementation planning.
- Guide 2 will later translate it into compliance operating-model planning.

## Boundary Note

This chapter does not invent new MRO numbering. It uses current GAIC source truth for MRO-01 through MRO-16.

---

# 7. Evidence Request List for Agentic Systems

**Candidate source status:** R4 publication-candidate preparation source **Chapter purpose:**

Define the logic of evidence requests for agentic systems without turning them into formal audit procedures. **Reader question:** What should reviewers ask to reconstruct agentic lifecycle work?

## Key Claims

- Evidence requests should be organized by lifecycle stage and review objective.
- Agentic evidence requests must cover role, authority, agent/tool action, outcomes, exceptions, privacy, partitioning, and closure.
- Evidence requests are readiness architecture, not universal legal demands or formal audit procedures.

## Source Grounding Note

Audit evidence and evidence sufficiency language is grounded in AUD-01 and AUD-02. Control and AI audit practice context comes from AUD-04, AUD-05, and AUD-06. AI governance/logging context may use AI-06.

## Author Synthesis Note

The evidence request taxonomy is WP2 author synthesis derived from GAIC MROs and



professional audit/control language.

## **Candidate Prose**

Agentic auditability becomes practical when it is expressed as evidence requests. A high-level statement that "the system is logged" is not enough. A reviewer needs to know what evidence should exist, where it lives, which lifecycle stage it supports, what role owns it, how sensitive fields are treated, and what boundary applies.

The evidence request list should begin with the lifecycle work unit. The reviewer should be able to ask: What work was initiated? What purpose and scope did it have? Who initiated it? Which agent or workflow received it? Which policy, authority, or business context applied? Without a work unit, later evidence cannot be connected.

The second request category is authority. What delegated authority allowed the agent to act? Was the action within scope? Did the authority have conditions, risk class, expiry, confirmation, or escalation requirements? If authority changed, was the change recorded? If authority drift occurred, was it escalated and closed?

The third category is responsibility. Which human role owned intent, review, acceptance, exception handling, and remediation? Which agent role executed the work? Was a responsibility transfer recorded across agents? Was a tool action tied back to a human or organizational owner? This category distinguishes accountability from technical execution.

The fourth category is tool-action evidence. Tool calls are where agent behavior often becomes operational consequence. Evidence should identify the tool, action, target system, affected data or process, response, reversibility, rollback path, and owner. The request is not asking for legal liability conclusions. It is asking for reconstructability.

The fifth category is outcome evidence. Reviewers should distinguish produced output from accepted outcome. Was the output accepted, rejected, disputed, escalated, or remediated? Who reviewed it? Which criteria or policy were applied? What evidence supports the final state?

The sixth category is exception and remediation. What event occurred? What lifecycle object was affected? Who owned the exception? What corrective action was taken? Was the action rechecked? Who accepted closure? What would reopen the issue?

The seventh category is privacy and selective disclosure. Evidence should not be over-collected or over-disclosed. Reviewers should ask for data categories, redaction profiles, retention rules,

disclosure scope, access logs, and minimization rationale. Legal interpretation remains outside WP2, but the evidence architecture should make privacy-aware review possible.

Finally, evidence requests should include boundary statements. Each request should clarify whether it supports readiness, reconstruction, control review, third-party review, or assurance planning. It should also clarify what it does not prove.

**Table 4: Lifecycle Stage -> Audit Evidence Request**

| Lifecycle stage | Core review question                | Evidence requested                                         | Human role                | Agent/tool record                 | Outcome/closure                 | Privacy treatment                    |
|-----------------|-------------------------------------|------------------------------------------------------------|---------------------------|-----------------------------------|---------------------------------|--------------------------------------|
| Intent          | What work was initiated and why?    | Work unit ID, purpose, scope, initiating context           | Request owner             | Initial agent/workflow assignment | No accepted outcome yet         | Purpose and data categories          |
| Delegation      | Was action authorized within scope? | Authority grant, conditions, expiry, confirmation boundary | Delegating/approving role | Agent permission and tool scope   | Escalation path                 | Minimum necessary authority evidence |
| Planning        | What plan or route was selected?    | Plan version, constraints, review flags                    | Plan reviewer if required | Agent plan trace                  | Plan accepted/rejected state    | Redacted sensitive prompts if needed |
| Tool action     | What external consequence occurred? | Tool identity, action, target, response, affected data,    | Tool-action owner         | Tool-call record, service trace   | Action status and rollback path | Data minimization and access scope   |

| Lifecycle stage | Core review question                 | Evidence requested                                                           | Human role       | Agent/tool record          | Outcome/closure            | Privacy treatment             |
|-----------------|--------------------------------------|------------------------------------------------------------------------------|------------------|----------------------------|----------------------------|-------------------------------|
|                 |                                      | reversibility                                                                |                  |                            |                            |                               |
| Handoff         | Was responsibility transferred?      | Source/target agent, transferred scope, retained scope, acceptance/rejection | Handoff owner    | Agent transfer record      | Transfer state             | Partition and disclosure rule |
| Review          | Was work reviewed before acceptance? | Review record, criteria, evidence pointer                                    | Reviewer role    | Supporting traces/outputs  | Accepted/rejected/disputed | Redaction profile             |
| Exception       | What deviation occurred?             | Exception record, baseline, trigger, impact                                  | Escalation owner | Incident trace or alert    | Open/remediated/closed     | Sensitive-data handling       |
| Closure         | Was remediation complete?            | Corrective action, recheck evidence, closure owner, reopen criteria          | Closure owner    | Remediation workflow trace | Closure state              | Retention/disclosure rule     |

**Table note:** Mixed source-grounded and author-synthesis table. It is a readiness evidence architecture, not a formal audit procedure, legal demand, or certification criterion.

## Cross-Links

- Appendix A expands the evidence request list.
- Appendix B turns these categories into a walkthrough template.
- Appendix E provides exception/remediation checklist detail.

## Boundary Note

Evidence requests do not prove legal compliance or audit sufficiency. A qualified professional must evaluate sufficiency in context.

---

# 8. Lifecycle Walkthrough for AI Agent / MAS Work

**Candidate source status:** R4 publication-candidate preparation source **Chapter purpose:**

Provide a reconstruction pattern for one agentic lifecycle run or work unit. **Reader question:**

How is one agentic workflow walked from intent to accepted outcome?

## Key Claims

- A lifecycle walkthrough should connect intent, authority, planning, execution, handoff, evidence, review, outcome, exception, remediation, and closure.
- The walkthrough is illustrative and readiness-oriented, not a formal audit procedure.
- Walkthroughs should preserve human role and agent role separation.

## Source Grounding Note

Control and walkthrough-adjacent language uses AUD-04, AUD-05, and AUD-06. Provenance and trace context uses EVID-01 and EVID-02. GAIC source truth provides MRO lifecycle objects.

## Author Synthesis Note

The agentic lifecycle walkthrough is WP2 author synthesis. It translates GAIC MROs and evidence request categories into a reconstruction pattern.

## **Candidate Prose**

A lifecycle walkthrough tests whether a single unit of agentic work can be reconstructed. It begins with a concrete work unit: a task, run, agent workflow, multi-agent handoff, tool action, or remediation event. The goal is not to prove compliance. The goal is to determine whether the evidence chain can explain the work from intent to closure.

The walkthrough should begin with intent and scope. What was the system asked to do? Who initiated the work? What business process, policy, or governance context applied? What was out of scope? The purpose of this step is to avoid reviewing an isolated output without understanding the work it belongs to.

The second step is authority. What authority allowed the agent or workflow to act? Was authority delegated by role, policy, system configuration, human confirmation, or another control? Did that authority include limits, expiry, risk class, confirmation requirements, or escalation paths? If the tool action exceeded scope, was that captured as exception or authority drift?

The third step is agent and tool identification. Which agent role acted? What constraints applied to that role? Which tools were available? Which tools were used? Which external systems, data stores, APIs, or processors were touched? The walkthrough should separate the agent role from the human role and the tool surface.

The fourth step is evidence pointer review. Where are logs, traces, workflow records, approvals, policies, tickets, evidence packs, or hash manifests stored? Are they linked by a stable work unit ID? Are there partition keys by agent, tool, role, vendor, project, data class, and lifecycle stage? Can an authorized reviewer reconstruct the chain without overexposing sensitive data?

The fifth step is outcome review. What output or action occurred? Was the outcome accepted, rejected, disputed, escalated, remediated, or closed? Who had authority to accept it? What evidence supports that state? An accepted outcome is a governance state, not just a completed workflow event.

The sixth step is exception and remediation review. If something deviated, did the system record the baseline, trigger, owner, corrective action, recheck, closure state, and reopen criteria? A lifecycle walkthrough is incomplete if it stops at detection and never reaches closure.

The seventh step is boundary review. What does the walkthrough support? It may support

readiness discussion, internal review, evidence request scoping, or future assurance planning. It does not itself produce an audit opinion, certification, legal conclusion, or regulator-approved result.

**Table 5: Human Role / Agent / Tool Responsibility Matrix**

| Lifecycle task          | Human role                           | Agent role                      | Tool/system                 | Authority basis                        | Evidence pointer                          | Escalation path                 |
|-------------------------|--------------------------------------|---------------------------------|-----------------------------|----------------------------------------|-------------------------------------------|---------------------------------|
| Initiate work           | Request owner                        | Intake agent                    | Workflow system             | Business request policy                | Work unit record                          | Reject or request clarification |
| Approve external action | Business owner or delegated approver | Execution agent                 | CRM/API/ configuration tool | Delegated authority record             | Authority evidence pointer and tool log   | Human confirmation or stop      |
| Transfer task           | Process owner                        | Source and target agents        | Orchestration runtime       | Handoff rule and inherited constraints | Responsibility transfer record            | Return/ reject/ escalate        |
| Review output           | Reviewer role                        | Drafting or analysis agent      | Document/ review system     | Review policy                          | Output, review note, evidence pointer     | Dispute or remediation          |
| Handle exception        | Incident/ remediation owner          | Monitoring or remediation agent | Ticketing/ incident system  | Escalation rule                        | Exception record and remediation evidence | Reopen, escalate, or close      |

**Table note:** GAIC-derived and author-synthesis table grounded in internal audit, control, provenance, and observability context. It assigns review responsibility for auditability purposes only and does not assign legal liability.

## Walkthrough Output

A completed walkthrough should produce:

- Work unit identity and scope.
- Authority boundary and confirmation history.
- Human role and agent role map.
- Tool-action evidence and side-effect summary.
- Evidence chain with pointers and partition keys.
- Accepted outcome or dispute state.
- Exception/remediation closure state if applicable.
- Privacy treatment and disclosure profile.
- Boundary statement describing what the walkthrough does and does not prove.

## Cross-Links

- Appendix B provides the walkthrough template.
- Chapter 9 addresses partitioning across agents, tools, vendors, and projects.
- Chapter 11 addresses exceptions and remediation closure.

## Boundary Note

The walkthrough is a reconstruction pattern for readiness and evidence design. It is not a formal audit procedure, assurance engagement step, or legal compliance test.

---

## 9. Evidence Partitioning Across Agents, Tools, Roles, Vendors, and Projects

**Candidate source status:** R4 publication-candidate preparation source **Chapter purpose:**

Define how evidence is separated and linked across lifecycle boundaries. **Reader question:**

How do reviewers avoid flattened responsibility in multi-agent and tool-mediated work?

## Key Claims

- Evidence must be partitioned and linkable across agent, tool, role, vendor, project, data class, jurisdiction, and lifecycle state where relevant.
- Partitioning enables reconstruction without blanket disclosure.
- Cross-project reuse, third-party processor chains, and vendor/model/runtime substitution

require explicit evidence boundaries.

### **Source Grounding Note**

Provenance and observability/logging context uses EVID-01, EVID-02, and EVID-03. Privacy context uses PRIV-01, PRIV-02, PRIV-03, and AI-09. GAIC source truth provides MRO-08, MRO-09, MRO-10, MRO-14, and MRO-15.

### **Author Synthesis Note**

The evidence partitioning model is WP2 author synthesis grounded in provenance, observability, privacy, and GAIC MROs.

### **Candidate Prose**

Agentic evidence becomes difficult to review when everything is flattened into one trace, one log export, one transcript, or one vendor report. Multi-agent systems distribute work across agents, tools, human roles, vendors, processors, projects, and data boundaries. Auditability requires those boundaries to be visible.

Partitioning is the discipline of separating evidence by review-relevant boundary while preserving the links needed for reconstruction. It is not the same as hiding evidence. It is not the same as retaining everything. It is a way to make evidence reviewable, scoped, and privacy-aware.

The first partition is the work unit. Every evidence item should connect to a lifecycle work unit or reconstruction path. Without a work unit, reviewers may know that events happened but not which lifecycle task they belong to.

The second partition is the agent. Agent roles may differ in authority, capability, tool access, evidence duties, and escalation requirements. If evidence only shows that "the system" acted, responsibility surfaces become blurred. Reviewers should be able to distinguish planning agents, execution agents, review agents, monitoring agents, and remediation agents where those roles exist.

The third partition is the tool. Tool actions often create external consequences. Evidence should separate model output from tool execution, tool execution from downstream system state, and reversible actions from irreversible or high-impact actions. Tool-specific evidence can include request/response logs, target system records, affected data categories, rollback records, and



owner information.

The fourth partition is the human role. A user account is not enough. Auditability requires role responsibility: request owner, delegating role, reviewer, acceptor, exception owner, remediation owner, privacy owner, or internal audit reviewer. These roles should connect to evidence without implying legal liability.

The fifth partition is vendor, processor, and runtime boundary. Agentic systems may call third-party tools, external APIs, model providers, orchestration runtimes, vector stores, workflow systems, or processors/subprocessors. Evidence should identify where responsibility, data processing, and review access shift. This is not vendor ranking. It is boundary mapping.

The sixth partition is project and reuse context. Cross-project reuse can move prompts, agents, workflows, memory, tools, or policies into a new context. Reuse may be efficient, but auditability requires evidence that scope, authority, privacy treatment, and evidence obligations were reset or revalidated for the new context.

The seventh partition is privacy and disclosure class. Some evidence can be disclosed directly. Some should be redacted. Some may require evidence pointers, hashes, summaries, or reviewer-specific access. The partitioning model should make it possible to review what is necessary without exposing more than the review requires.

**Table 6: Evidence Partitioning Matrix**

| Partition dimension | Why it matters                    | Evidence boundary                         | Access/disclosure rule         | Failure if missing             | Related MRO            |
|---------------------|-----------------------------------|-------------------------------------------|--------------------------------|--------------------------------|------------------------|
| Work unit           | Anchors reconstruction            | Work unit ID and lifecycle stage          | Reviewer access tied to scope  | Evidence cannot be connected   | MRO-08                 |
| Agent               | Separates responsibility surfaces | Agent ID, role, constraints, work segment | Role-based evidence disclosure | Flattened agent responsibility | MRO-03, MRO-06, MRO-08 |
| Tool                | Tracks external consequence       | Tool ID, target system, action type,      | Tool-specific disclosure and   | Unclear side effects           | MRO-05, MRO-08         |

| Partition dimension        | Why it matters                             | Evidence boundary                                    | Access/disclosure rule            | Failure if missing                        | Related MRO            |
|----------------------------|--------------------------------------------|------------------------------------------------------|-----------------------------------|-------------------------------------------|------------------------|
|                            |                                            | reversibility                                        | redaction                         |                                           |                        |
| Human role                 | Connects governance ownership              | Role map, approval, review, acceptance, closure      | Need-to-know reviewer access      | User identity mistaken for responsibility | MRO-01                 |
| Vendor / processor         | Maps third-party boundary                  | Vendor/processor role, subprocessor chain, data path | Contract/privacy-aware disclosure | Responsibility chain disappears           | MRO-14                 |
| Project / reuse context    | Prevents context drift                     | Source context, target context, reset validation     | Reuse-specific review access      | Old authority/policy reused incorrectly   | MRO-09                 |
| Runtime/model substitution | Preserves evidence continuity after change | Prior/new component, revalidation evidence           | Change-scoped disclosure          | Evidence chain breaks after substitution  | MRO-15                 |
| Privacy class              | Limits overexposure                        | Data category, redaction profile, retention rule     | Minimized disclosure              | Privacy leakage or evidence hoarding      | MRO-10, MRO-12, MRO-13 |

**Table note:** Mixed source-grounded and author-synthesis table. It does not create universal disclosure or retention rules, vendor rankings, or procurement recommendations.

## Cross-Links

- Chapter 10 covers privacy and selective disclosure.

- Appendix A includes partition fields for evidence requests.
- Appendix C maps partitioning to MRO-08, MRO-09, MRO-14, and MRO-15.

## Boundary Note

Partitioning is a review architecture. It does not decide legal retention, data subject rights, processor obligations, or vendor liability.

---

---

## 10. Privacy, Selective Disclosure, and Audit Evidence Minimization

**Candidate source status:** R4 publication-candidate preparation source **Chapter purpose:** Balance auditability with privacy, confidentiality, minimization, and retention discipline. **Reader question:** How can evidence be reviewable without overexposure?

### Key Claims

- Auditability should not become evidence hoarding.
- Privacy-aware auditability uses minimization, redaction, retention discipline, evidence pointers, partitioning, and selective disclosure.
- WP2 frames privacy/evidence tension; it does not provide legal advice or GDPR compliance proof.

### Source Grounding Note

Privacy and minimization context uses PRIV-01, PRIV-02, PRIV-03, PRIV-04, PRIV-05, and AI-09. GAIC source truth provides MRO-10 through MRO-13 and the Validation Lab selective disclosure boundary.

### Author Synthesis Note

The privacy-preserving audit evidence controls are WP2 synthesis grounded in public privacy guidance and GAIC MROs.

### Candidate Prose

Auditability can create a privacy problem if it is misunderstood. The answer to weak evidence is not to collect everything forever. Agentic systems may process personal data, confidential business data, privileged material, regulated data, customer records, employee records,

prompts, outputs, tool responses, logs, memory, and third-party processor data. If auditability becomes indiscriminate evidence capture, it may increase exposure and reduce trust.

The better question is: what evidence is necessary for the review objective, and how can it be disclosed safely? This requires minimization, partitioning, retention discipline, access control, redaction, evidence pointers, and reviewer-specific disclosure profiles.

Privacy-aware auditability begins with purpose. Evidence should be collected and retained for defined review purposes: reconstruction, control review, exception handling, third-party validation, remediation, or assurance planning. A generic desire to "keep all logs just in case" is not a mature evidence strategy.

The second principle is minimization. Evidence objects should identify what fields are needed for reconstruction and which fields can be redacted, tokenized, summarized, hashed, or replaced with pointers. A reviewer may need to know that a tool action affected a customer data category without seeing every raw value. Another reviewer may need access under a narrower approved scope. The evidence architecture should support both.

The third principle is selective disclosure. Different reviewers need different levels of evidence. Internal engineering may need logs and traces. Internal audit may need work unit chains and evidence pointers. Privacy teams may need data category and retention records. Third-party reviewers may need redacted evidence packs, ruleset identity, verdict hashes, or replay packages. The system should make disclosure explicit, scoped, and recorded.

The fourth principle is retention discipline. Evidence needs may conflict with storage limitation and deletion expectations. WP2 does not decide legal retention periods. It asks that systems record retention rules, expiry, holds, deletion/redaction actions, and rights-retention reconciliation where relevant. A reviewable retention decision is stronger than a silent default.

The fifth principle is boundary clarity. Privacy sources provide context, not legal conclusions. A privacy-preserving evidence architecture does not prove GDPR compliance, UK GDPR compliance, EU AI Act compliance, or any jurisdiction-specific legal compliance. It creates the object layer that legal, privacy, audit, and governance professionals can review.

**Table 7: Privacy-Preserving Audit Evidence Controls**

| Control                         | Purpose                                              | Evidence artifact                              | Selective disclosure mechanism        | Privacy risk reduced                        | Residual review need                           |
|---------------------------------|------------------------------------------------------|------------------------------------------------|---------------------------------------|---------------------------------------------|------------------------------------------------|
| Evidence minimization           | Avoid unnecessary collection                         | Minimization rule, field inventory             | Request only review-relevant fields   | Overcollection                              | Legal/privacy review for purpose and necessity |
| Redaction profile               | Remove or mask sensitive fields                      | Redaction rule and redaction log               | Redacted evidence pointer             | Overexposure to reviewer                    | Sufficiency check after redaction              |
| Evidence pointer                | Reference evidence without copying raw data          | Pointer, hash, manifest entry                  | Reviewer-scoped access or replay      | Data duplication                            | Integrity and access review                    |
| Retention rule                  | Limit storage duration or define hold                | Retention schedule, expiry, hold indicator     | Time-bound access                     | Excessive retention                         | Legal/privacy retention analysis               |
| Disclosure profile              | Define who can see what                              | Disclosure matrix, access log                  | Role-based disclosure package         | Unscoped sharing                            | Reviewer authorization review                  |
| Rights-retention reconciliation | Address tension between rights requests and evidence | Request record, action, hold status, rationale | Redaction/deletion/hold decision path | Silent conflict between evidence and rights | Legal review                                   |

| Control                        | Purpose                             | Evidence artifact                                | Selective disclosure mechanism | Privacy risk reduced     | Residual review need         |
|--------------------------------|-------------------------------------|--------------------------------------------------|--------------------------------|--------------------------|------------------------------|
|                                | retention                           |                                                  |                                |                          |                              |
| Third-party validation package | Support review without raw exposure | Redacted evidence pack, ruleset ID, verdict hash | Non-raw evidence adjudication  | Third-party overexposure | Boundary and conflict review |

**Table note:** Source-grounded and GAIC-derived table. It is not legal advice, privacy compliance proof, or universal retention guidance.

### Cross-Links

- Chapter 9 addresses evidence partitioning.
- Chapter 12 addresses third-party validation boundaries.
- Appendix F provides privacy/legal boundary language.

### Boundary Note

This chapter does not provide legal advice, interpret specific legal obligations, or claim that any architecture proves compliance with GDPR, UK GDPR, EU AI Act, or other privacy laws.

## 11. Exception, Dispute, and Remediation Closure

**Candidate source status:** R4 publication-candidate preparation source **Chapter purpose:** Define closure evidence for failed, disputed, drifted, or remediated agentic work. **Reader question:** How does auditability handle exceptions and closure?

### Key Claims

- Exceptions, disputes, authority drift, outcome rejection, and remediation must close as evidence-backed lifecycle states.
- Incident logs alone do not prove closure.
- Closure evidence should identify owner, corrective action, recheck, accepted closure

state, and reopen criteria.

### **Source Grounding Note**

Incident/governance context uses EVID-04 and AI-02. Control and AI audit practice context uses AUD-04, AUD-05, and AUD-06. GAIC source truth provides MRO-04, MRO-07, and MRO-16.

### **Author Synthesis Note**

Remediation closure as an audit evidence state is WP2/GAIC synthesis. It is not a legal settlement, regulator closure, or assurance conclusion.

### **Candidate Prose**

Agentic auditability is incomplete if it only reconstructs successful work. Many of the most important review questions arise when an agent acts outside expected authority, a tool action creates unintended consequence, an outcome is disputed, a privacy issue appears, a handoff fails, or remediation is required.

In ordinary operations, exceptions often become tickets. Tickets are useful, but they are not automatically lifecycle evidence. A ticket may describe an issue, assign an owner, record comments, and mark a status. For auditability, the ticket must connect to the agentic work unit, authority boundary, role map, tool action, evidence pointer, accepted outcome state, privacy treatment, corrective action, and closure state.

Closure is the critical concept. An incident can be detected without being remediated. A remediation can be attempted without being rechecked. A recheck can occur without being accepted. An accepted closure can later be reopened. Auditability requires those state transitions to be evidence-backed.

For agentic systems, exceptions should be categorized by lifecycle object. Was the issue an authority exception, where observed behavior exceeded delegated scope? Was it a responsibility exception, where no human owner could be identified? Was it a tool-action exception, where a tool created unexpected side effects? Was it an accepted-outcome dispute, where a result was produced but not accepted? Was it a privacy exception, where evidence collection or disclosure exceeded the intended boundary? Was it a substitution exception, where evidence integrity broke after runtime/model/tool change?

The closure record should answer five questions:

1. What happened and which lifecycle object was affected?
2. Who owned the exception and remediation?
3. What corrective action was taken?
4. What evidence shows recheck or review?
5. Who accepted closure, and what would reopen the issue?

None of these questions determines legal fault. None proves regulatory acceptance. None settles liability. They make the remediation lifecycle reconstructable.

**Table 10: Exception / Dispute / Remediation Evidence Checklist**

| Event type              | Evidence required                                                | Owner             | Escalation path                                     | Remediation record                    | Closure evidence                        | Boundary                |
|-------------------------|------------------------------------------------------------------|-------------------|-----------------------------------------------------|---------------------------------------|-----------------------------------------|-------------------------|
| Authority exception     | Baseline authority, observed action, trigger, affected work unit | Escalation owner  | Stop, downgrade, reauthorize, or human confirmation | Reauthorization or stop-action record | Closure acceptance and new boundary     | Not legal determination |
| Outcome dispute         | Output, acceptance criteria, dispute reason, reviewer notes      | Review owner      | Secondary review or remediation                     | Correction/review path                | Accepted, rejected, or remediated state | Not settlement proof    |
| Tool-action side effect | Tool call, target system, affected data/proc                     | Tool-action owner | Rollback, disable, escalate                         | Rollback or corrective action         | Recheck and owner acceptance            | Not liability finding   |



| Event type         | Evidence required                                          | Owner             | Escalation path               | Remediation record                               | Closure evidence                      | Boundary                          |
|--------------------|------------------------------------------------------------|-------------------|-------------------------------|--------------------------------------------------|---------------------------------------|-----------------------------------|
|                    | ess,<br>reversibility                                      |                   |                               |                                                  |                                       |                                   |
| Privacy event      | Data category, disclosure path, redaction/retention record | Privacy owner     | Privacy/legal review          | Redaction, deletion, hold, or access restriction | Review note and disclosure update     | Not legal advice                  |
| Handoff failure    | Source/target agent, transferred scope, retained scope     | Process owner     | Return, reassign, or escalate | Transfer correction                              | Accepted transfer or closed exception | Not legal responsibility transfer |
| Remediation defect | Prior closure evidence, reopened issue, failed recheck     | Remediation owner | Reopen and reassign           | Updated corrective action                        | Recheck and closure reviewer          | Not regulator closure             |

**Table note:** Mixed source-grounded, GAIC-derived, and author-synthesis checklist. It is not an audit procedure, legal remedy checklist, or certification criterion.

## Cross-Links

- Appendix E provides an expanded closure checklist.

- Chapter 13 includes exception traceability and remediation closure as AARM dimensions.
- Chapter 16 connects closure to future Guide 1, Guide 2, and WP3.

### **Boundary Note**

Closure in this chapter means evidence-backed governance closure. It does not mean legal closure, settlement, regulator acceptance, assurance opinion, or certification.

---

## **12. Third-Party Validation Without Certification Claims**

**Candidate source status:** R4 publication-candidate preparation source **Chapter purpose:**

Define how evidence review can involve third parties without becoming certification, assurance opinion, conformity assessment, legal proof, or regulator approval. **Reader question:** What can third-party validation support without becoming certification?

### **Key Claims**

- Third-party validation can support evidence review, replay, adjudication, and readiness discussion.
- Third-party validation does not certify compliance or issue assurance opinions unless a separate authorized engagement or conformity-assessment framework exists.
- Validation Lab is only a non-certifying evidence adjudication example.

### **Source Grounding Note**

Assurance and attestation boundaries are grounded in AUD-03 and BOUND-03. Conformity-assessment and validation/verification boundaries are grounded in BOUND-01 and BOUND-02. Validation Lab boundary is GAIC source truth.

### **Author Synthesis Note**

WP2's third-party validation boundary is author synthesis that uses professional boundary sources to avoid overclaim. It does not define a conformity assessment program.

### **Candidate Prose**

Agentic auditability often benefits from independent review. A third party, internal audit team, governance function, or specialized review group may inspect evidence packs, replay work

units, test whether evidence objects exist, adjudicate ruleset conformance, or evaluate whether evidence chains are reconstructable. These activities can be valuable.

They are also easy to overstate. Evidence review is not automatically certification. Validation is not automatically an assurance opinion. A verdict hash is not regulator approval. A ruleset check is not legal compliance proof. A third-party review note is not an audit report unless it is performed under an appropriate professional engagement, criteria, scope, independence framework, and reporting structure.

This chapter exists to keep that boundary visible. WP2 uses "third-party validation" in a narrow sense: review of evidence against defined rulesets or reconstruction objectives. The review may support readiness, evidence quality, selective disclosure, replay, exception closure, or future assurance planning. It does not itself create certification or assurance.

Validation Lab is a useful boundary example because GAIC already frames it as non-certifying evidence adjudication. In WP2, Validation Lab should only be described as one example of how evidence-based validation might be operationalized. It must not be described as the only validation path, a certification body, a regulator, an audit firm, an assurance provider, a conformity assessment body, or proof of enterprise readiness.

The distinction matters for enterprises. If an organization receives a third-party evidence review, it should know exactly what was reviewed, against what ruleset, under what scope, with what evidence, and with what limitations. A review may show that evidence exists and can be replayed. It may show that a ruleset passed. It may show that disclosure was minimized. But it does not determine legal compliance or professional audit sufficiency.

The same distinction matters for reviewers. A review team should state its role: internal readiness review, independent evidence review, validation, verification, assurance engagement, attestation engagement, certification, or legal analysis. Each role has different requirements. WP2 only defines the auditability object layer that may support those roles.

**Table 8: Third-Party Validation Boundary Table**

| Review activity       | Can support         | Cannot prove        | Evidence artifact    | Boundary language       | Source IDs   |
|-----------------------|---------------------|---------------------|----------------------|-------------------------|--------------|
| Evidence adjudication | Ruleset conformance | Legal compliance or | Ruleset ID, evidence | Non-certifying evidence | GAIC-SOURCE, |

| Review activity              | Can support                                  | Cannot prove                                                          | Evidence artifact                                        | Boundary language                               | Source IDs                      |
|------------------------------|----------------------------------------------|-----------------------------------------------------------------------|----------------------------------------------------------|-------------------------------------------------|---------------------------------|
|                              | review                                       | audit opinion                                                         | pointer, verdict/hash record                             | review                                          | BOUND-01                        |
| Evidence replay              | Reconstructability check                     | Operating effectiveness across all periods                            | Replay package, work unit chain, integrity record        | Scope-limited reconstruction                    | EVID-01, AUD-01                 |
| Selective disclosure review  | Privacy-aware review process                 | Privacy law compliance                                                | Redaction profile, disclosure log, reviewer access scope | Privacy-aware evidence review, not legal advice | PRIV-01 to PRIV-05              |
| Third-party readiness review | Independent input to readiness discussion    | Assurance conclusion                                                  | Scope statement, findings, limitations                   | Readiness input only                            | AUD-03, BOUND-03                |
| Validation Lab example       | Non-certifying evidence adjudication example | Certification, regulator approval, conformity assessment, legal proof | Verdict hash, ruleset identity, evidence pointer         | One optional example, not exclusive path        | GAIC-SOURCE, BOUND-01, BOUND-02 |
| Assurance engagement         | Professional assurance under                 | Anything outside                                                      | Practitioner report,                                     | Outside WP2 unless                              | AUD-03,                         |

| Review activity | Can support                            | Cannot prove     | Evidence artifact               | Boundary language     | Source IDs |
|-----------------|----------------------------------------|------------------|---------------------------------|-----------------------|------------|
|                 | separate criteria and engagement terms | engagement scope | criteria, scope, evidence basis | separately authorized | BOUND-03   |

**Table note:** Source-grounded boundary table with GAIC-derived example. It is not a certification model, audit procedure, or assurance engagement template.

### Cross-Links

- Appendix F provides reusable boundary language.
- Appendix D uses third-party review boundary as an AARM dimension.
- Chapter 15 explains professional use by audit and assurance firms.

### Boundary Note

This chapter must not be read as claiming that any third party, including Validation Lab, certifies agentic systems, issues legal opinions, provides assurance opinions, or has regulator approval.

---

## 13. Agentic Auditability Readiness Model

**Candidate source status:** R4 publication-candidate preparation source **Chapter purpose:** Present AARM dimensions and readiness levels as a proposed readiness model. **Reader question:** How can auditability readiness be described without claiming assurance?

### Key Claims

- AARM describes readiness for reconstructability, testability, evidence structure, privacy-aware review, and third-party review boundaries.
- AARM is proposed WP2 synthesis.
- AARM is not a score, audit standard, certification, assurance opinion, legal compliance proof, regulator approval, procurement tool, or vendor ranking.

## **Source Grounding Note**

Audit evidence language uses AUD-01. AI audit practice context uses AUD-05 and AUD-06. AI governance context uses AI-01. Attestation boundary context uses BOUND-03. R4B/R1 AARM baseline and GAIC source truth provide the model structure.

## **Author Synthesis Note**

AARM is WP2 author synthesis. It is a readiness vocabulary, not an external maturity model or professional assurance framework.

## **Candidate Prose**

Once evidence objects are defined, organizations need a way to discuss readiness. AARM provides that vocabulary. It asks whether agentic lifecycle work can be reconstructed, tested, evidenced, and reviewed across the object areas this paper has defined.

AARM deliberately avoids scoring. Scores invite overprecision and can be mistaken for certification, compliance grades, vendor rankings, or procurement guidance. AARM instead uses dimensions and levels. The dimensions ask what must be reviewable. The levels describe the degree to which the lifecycle work is observable, trace-linked, evidence-structured, auditability-ready, or assurance-ready for planning.

The word "Assurance-Ready" is sensitive. In AARM, it does not mean assurance has been issued. It means the evidence architecture may be mature enough to support qualified assurance planning or review within a defined scope. It still depends on professional scope, criteria, independence, engagement acceptance, and judgment, and it does not guarantee a positive result.

The ten AARM dimensions are:

1. Audit object clarity.
2. Authority traceability.
3. Human / agent responsibility mapping.
4. Evidence sufficiency.
5. Agent/tool partitioning.
6. Exception traceability.
7. Accepted outcome evidence.
8. Remediation closure.

9. Privacy and selective disclosure.

10. Third-party review boundary.

The levels describe readiness states. L0 Unobservable means lifecycle work cannot be reconstructed beyond informal narrative or final output. L1 Log-Visible means logs exist but responsibility linkage is weak. L2 Trace-Linked means traces connect some actions to agents, tools, or workflows. L3 Evidence-Structured means lifecycle evidence objects exist. L4 Auditability-Ready means defined-scope evidence chains can reconstruct authority, responsibility, tools, outcomes, exceptions, privacy, and closure. L5 Assurance-Ready means evidence architecture may support professional assurance planning or review within a defined scope.

The main use of AARM is conversation discipline. It helps technology leaders avoid saying "we have logs, so we are audit-ready." It helps governance teams ask whether accepted outcomes and remediation closure are evidence states. It helps audit teams separate raw observability from reconstructable evidence. It helps privacy teams see whether selective disclosure is built in. It helps third-party reviewers clarify what their review does and does not mean.

**Table 9: Auditability Readiness Levels**

| Level           | Definition                                                                           | Observable traits                                                                   | Minimum evidence                         | What it does not prove                                          | Source / synthesis note                              |
|-----------------|--------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|------------------------------------------|-----------------------------------------------------------------|------------------------------------------------------|
| L0 Unobservable | Lifecycle work cannot be reconstructed beyond informal narrative or isolated outputs | Missing lifecycle IDs, no authority linkage, no role map, no accepted outcome state | None beyond ad hoc notes or final output | Absence of risk, absence of non-compliance, or system safety    | Author synthesis grounded in AUD-01/AU02 expectation |
| L1 Log-Visible  | Activity logs exist without responsibility-linked evidence chains                    | Logs, traces, timestamps, tool events                                               | Raw logs or trace exports                | Authority, responsibility, acceptance, exception closure, audit | EVID-02/ EVID-03 + WP2 synthesis                     |

| Level                  | Definition                                                               | Observable traits                                                                       | Minimum evidence                                                  | What it does not prove                                             | Source / synthesis note                                    |
|------------------------|--------------------------------------------------------------------------|-----------------------------------------------------------------------------------------|-------------------------------------------------------------------|--------------------------------------------------------------------|------------------------------------------------------------|
|                        |                                                                          |                                                                                         |                                                                   | readiness                                                          |                                                            |
| L2 Trace-Linked        | Logs/traces link some actions to agents, tools, users, or workflows      | Workflow IDs, agent/tool traces, partial actor linkage                                  | Trace-linked run records and partial evidence map                 | Complete lifecycle responsibility or sufficient evidence           | EVID-01/<br>EVID-02 + WP2 synthesis                        |
| L3 Evidence-Structured | Lifecycle evidence is organized into objects that support reconstruction | Role maps, authority objects, accepted outcome records, partitioning, exception records | MRO-aligned evidence objects and sampled walkthroughs             | Assurance readiness, legal compliance, operating effectiveness     | GAIC-derived + AUD-01/AUD-04/AUD-05                        |
| L4 Auditability-Ready  | Evidence chains can reconstruct defined-scope agentic lifecycle work     | Walkthroughs, evidence request response, privacy controls, closure evidence             | Complete evidence chain for defined scope plus boundary statement | Audit opinion, certification, regulator approval, legal compliance | WP2 synthesis grounded in audit/provenance/privacy sources |
| L5 Assurance-Ready     | Evidence architecture may support professional assurance planning        | Repeatable evidence packs, ruleset identity, reviewer                                   | Reviewable evidence packs, integrity records,                     | Actual assurance opinion, certification, guaranteed                | WP2 synthesis bounded by AUD-03/BO                         |



| Level | Definition                       | Observable traits                        | Minimum evidence   | What it does not prove           | Source / synthesis note |
|-------|----------------------------------|------------------------------------------|--------------------|----------------------------------|-------------------------|
|       | or review within a defined scope | scope,<br>remediation/re check procedure | boundary statement | compliance, regulator acceptance | ND-03                   |

**Table note:** AARM is author synthesis grounded in source language. It is not a score, standard, certification, assurance conclusion, procurement benchmark, or vendor ranking.

### AARM Dimension Summary

| Dimension                            | Audit question                                                | Minimum evidence family                     | Primary MRO links       | Boundary                   |
|--------------------------------------|---------------------------------------------------------------|---------------------------------------------|-------------------------|----------------------------|
| Audit object clarity                 | Can reviewers name the lifecycle unit under review?           | Work unit ID, scope, object inventory       | MRO-01, MRO-03, MRO-04  | Not legal category         |
| Authority traceability               | Was the action authorized under scope?                        | Authority grant, expiry, escalation         | MRO-02, MRO-07          | Not legal delegation proof |
| Human / agent responsibility mapping | Who owned intent, execution, review, acceptance, remediation? | Role map and transfer record                | MRO-01, MRO-03, MRO-06  | No anthropomorphism        |
| Evidence sufficiency                 | Can reviewers reconstruct work without narrative memory?      | Evidence chain and pointers                 | MRO-04, MRO-08, MRO-16  | Not universal sufficiency  |
| Agent/tool partitioning              | Can actions be separated across agents/tools/vendors/         | Partition keys, tool evidence, substitution | MRO-05, MRO-08, MRO-14, | No vendor ranking          |

| Dimension                        | Audit question                                    | Minimum evidence family                     | Primary MRO links      | Boundary                           |
|----------------------------------|---------------------------------------------------|---------------------------------------------|------------------------|------------------------------------|
|                                  | projects?                                         | record                                      | MRO-15                 |                                    |
| Exception traceability           | Can deviation be linked to owner and next action? | Exception record and impact scope           | MRO-07, MRO-16         | Not legal violation                |
| Accepted outcome evidence        | Who accepted or disputed the result?              | Outcome state, reviewer role, evidence link | MRO-04                 | Not compliance proof               |
| Remediation closure              | What was remediated and who accepted closure?     | Corrective action, recheck, closure state   | MRO-16                 | Not settlement                     |
| Privacy and selective disclosure | Can review occur without unnecessary exposure?    | Redaction, retention, disclosure profile    | MRO-10 to MRO-13       | Not legal advice                   |
| Third-party review boundary      | What can a reviewer inspect and claim?            | Scope, ruleset, verdict, boundary statement | MRO-11, MRO-12, MRO-16 | No certification/assurance opinion |

## Cross-Links

- Appendix D provides the expanded readiness matrix.
- Chapter 14 connects AARM to enterprise readiness.
- Chapter 15 connects AARM to professional use boundaries.

## Boundary Note

AARM is a readiness model only. It does not prove legal compliance, issue assurance, certify systems, rank vendors, bind regulators, or require MPLP.

---

---

## 14. Enterprise Implementation: CIO / CTO / CCO Readiness

**Candidate source status:** R4 publication-candidate preparation source **Chapter purpose:**

Connect WP2 to enterprise readiness without replacing Guide 1 or Guide 2. **Reader question:**

What must leaders prepare before auditability or assurance conversations become credible?

### Key Claims

- Audit-ready agentic systems require architecture, governance, evidence ownership, privacy controls, exception closure, and role clarity.
- CIO/CTO readiness focuses on technical evidence architecture.
- CCO readiness focuses on policy-to-evidence governance.
- WP2 bridges to Guide 1 and Guide 2 but does not replace them.

### Source Grounding Note

Enterprise control context uses AUD-04 and AUD-07. AI governance context uses AI-01 and PRIV-03. Big Four sources BF-02 and BF-04 provide market context only. GAIC source truth provides Guide 1/Guide 2 boundaries.

### Author Synthesis Note

The CIO/CTO/CCO readiness split is WP2 author synthesis derived from R4C Guide planning and WP2 audit evidence architecture.

### Candidate Prose

Enterprises do not become audit-ready by exporting logs at the end of an agentic workflow. Auditability must be designed into architecture, governance, review routines, and evidence ownership. WP2 is not an implementation guide, but it defines the readiness questions leaders should ask before Guide 1 and Guide 2 translate the framework into practice.

For CIOs and CTOs, the first question is whether the system can produce evidence by design. Agent runtimes, orchestration layers, tool integrations, workflow engines, ticketing systems, approval systems, data stores, and logging platforms must be able to preserve the relationships that matter: work unit, authority, role, tool action, evidence pointer, outcome, exception, privacy treatment, and closure. If these relationships are not captured at runtime, auditability becomes after-the-fact reconstruction.

The second technology question is partitioning. Evidence should be separable by agent, tool,

role, vendor, project, data class, lifecycle state, and review purpose. This requires stable identifiers, metadata, access controls, retention logic, evidence export, and selective disclosure. It may also require integration with existing observability, security, data governance, and workflow systems.

The third technology question is change. Agentic systems change as models, prompts, tools, vendors, runtimes, policies, workflows, and memory stores change. Auditability requires substitution records, evidence continuity checks, regression evidence, reauthorization triggers, and revalidation boundaries. A system that loses evidence continuity after a runtime change is not auditability-ready for that scope.

For CCOs and governance leaders, the first question is policy-to-evidence translation. Policies should not only describe desired behavior; they should identify the evidence object that proves the policy was operationalized. A delegated authority policy should map to authority records. A human oversight policy should map to role and confirmation records. A remediation policy should map to closure evidence.

The second governance question is role operating model. The IIA Three Lines context is useful here as governance vocabulary, not as a WP2 mandate. Management, risk/compliance, internal audit, privacy, security, legal, and technology teams need different evidence views and responsibilities. WP2 helps name the evidence layer they must share.

The third governance question is review cadence. Agentic auditability is not a one-time readiness exercise. Evidence objects should be sampled, walked through, rechecked after change, reviewed after exceptions, and re-evaluated when authority, vendor, model, runtime, or privacy conditions change.

Guide 1 will later turn these questions into technical architecture planning. Guide 2 will later turn them into compliance operating-model routines. WP2 should not absorb those details. It should define the evidence object layer that both guides will implement.

**Enterprise Readiness Crosswalk**

| Readiness area | CIO / CTO question | CCO / governance question | Evidence object | Guide relation | Boundary  |
|----------------|--------------------|---------------------------|-----------------|----------------|-----------|
| Work unit      | Can systems        | Which work types          | Work unit       | Guide 1        | Not audit |

| Readiness area | CIO / CTO question                                                        | CCO / governance question                                              | Evidence object                  | Guide relation                          | Boundary                       |
|----------------|---------------------------------------------------------------------------|------------------------------------------------------------------------|----------------------------------|-----------------------------------------|--------------------------------|
| identity       | assign stable lifecycle IDs?                                              | require evidence?                                                      | record                           | architecture;<br>Guide 2 policy scope   | procedure                      |
| Authority      | Can delegated authority be enforced and logged as business scope?         | Which policies define authority, expiry, confirmation, and escalation? | Delegated authority record       | Guide 1 controls;<br>Guide 2 governance | Not legal delegation proof     |
| Role mapping   | Can human/agent roles be captured separately?                             | Who owns intent, review, acceptance, and closure?                      | Responsibility map               | Both guides                             | Not legal liability assignment |
| Tool actions   | Can consequential tool actions generate evidence?                         | Which tool actions require review or confirmation?                     | Tool-action evidence             | Guide 1 high relevance                  | No liability conclusion        |
| Privacy        | Can evidence be minimized, redacted, retained, and selectively disclosed? | Which privacy rules and approvals govern review?                       | Disclosure and retention profile | Both guides                             | No legal advice                |
| Exceptions     | Can exceptions link to lifecycle objects and closure?                     | Who governs dispute/remediation on workflow?                           | Exception/remediation record     | Both guides                             | No legal remedy claim          |
| Third-party    | Can evidence be                                                           | What can third                                                         | Validation                       | Guide 1                                 | No                             |

| Readiness area | CIO / CTO question        | CCO / governance question   | Evidence object              | Guide relation                  | Boundary      |
|----------------|---------------------------|-----------------------------|------------------------------|---------------------------------|---------------|
| review         | exported/replayed safely? | parties claim or not claim? | scope and boundary statement | export; Guide 2 review boundary | certification |

**Table note:** Author-synthesis crosswalk grounded in controls, governance, privacy, and GAIC Guide planning. It is not procurement guidance or readiness guarantee.

### Cross-Links

- Guide 1 will own technical implementation details.
- Guide 2 will own compliance operating-model details.
- Appendix D can be used as a readiness conversation input.

### Boundary Note

This chapter does not claim that following WP2 makes an enterprise compliant, audit-ready in a professional engagement, certified, regulator-approved, or procurement-preferred.

---

## 15. How Audit and Assurance Firms Can Use This Framework

**Candidate source status:** R4 publication-candidate preparation source **Chapter purpose:**

Define cautious professional use without claiming endorsement, replacement methodology, assurance opinion, or standard-setting status. **Reader question:** How might audit and assurance firms use WP2 responsibly?

### Key Claims

- Audit and assurance firms may use WP2 as a conceptual object/evidence request and readiness framing tool.
- WP2 can support discussion, scoping, evidence request design, walkthrough planning, and methodology exploration.
- WP2 does not replace professional methodology, engagement criteria, independence, judgment, standards, or reporting.

## **Source Grounding Note**

Big Four context uses BF-02 and BF-03 as market context only. Assurance boundary uses AUD-03 and BOUND-03. AI audit practice context uses AUD-05 and AUD-06.

## **Author Synthesis Note**

The professional-use framing is WP2 author synthesis. It is intentionally cautious and non-endorsement based.

## **Candidate Prose**

WP2 is relevant to audit and assurance firms because agentic AI changes the evidence question. Firms already discuss AI assurance, trusted AI, audit transformation, technology-enabled assurance, governance, controls, and responsible AI. Agentic systems add another layer: lifecycle work that must be reconstructed across authority, responsibility, agents, tools, outcomes, exceptions, privacy, and remediation.

The safest professional use of WP2 is as a framing tool. It can help teams ask what the review object is. It can help distinguish logs from audit evidence chains. It can help convert governance concerns into evidence requests. It can help structure walkthrough conversations. It can help identify whether an enterprise has evidence gaps before any formal assurance claim is discussed.

WP2 may also help methodology teams think about agentic evidence architecture. A method team could use the Agentic Audit Object as a conceptual lens: What lifecycle work unit is under review? What authority record exists? What human role accepted the outcome? What tool-action evidence exists? What exception state or remediation closure exists? What privacy treatment governs disclosure?

Internal audit teams may use WP2 differently. They may use it to scope readiness reviews, design evidence request lists, test walkthrough templates, ask whether human oversight is evidence-backed, or evaluate whether remediation closure is reconstructable. Again, this use is readiness-oriented. It does not transform WP2 into an internal audit standard.

Assurance teams must be especially careful. AARM's "Assurance-Ready" level does not mean assurance has been issued or is guaranteed. It means that an evidence architecture may be mature enough to support qualified assurance planning or review, subject to the firm's professional standards, criteria, engagement scope, independence, risk assessment, evidence

evaluation, and reporting requirements.

WP2 should never be represented as a Big Four methodology. It should never be described as endorsed by Deloitte, PwC, EY, KPMG, ISACA, IIA, IAASB, PCAOB, AICPA, ISO, NIST, OECD, EU institutions, Singapore agencies, ICO, or any source organization. Sources provide context and terminology. They do not approve this framework.

## Professional Use Matrix

| Use case                | WP2 can support                                                                | WP2 cannot replace                             | Useful objects                             | Boundary                |
|-------------------------|--------------------------------------------------------------------------------|------------------------------------------------|--------------------------------------------|-------------------------|
| Readiness conversation  | Shared vocabulary for auditability gaps                                        | Professional judgment or engagement acceptance | AARM, evidence chain, object model         | No assurance conclusion |
| Evidence request design | Categories for authority, roles, tools, outcomes, exceptions, privacy, closure | Audit procedures or legal demands              | Appendix A request list                    | Not formal procedure    |
| Walkthrough scoping     | Lifecycle reconstruction pattern                                               | Sampling methodology or engagement workplan    | Appendix B walkthrough                     | Illustrative only       |
| Internal audit review   | Auditability gap identification                                                | Internal audit standards or final reports      | MRO mapping, closure checklist             | No standard-setting     |
| Methodology exploration | Object model for agentic work                                                  | Firm methodology or regulatory requirements    | Agentic Audit Object, Audit Evidence Chain | No Big Four endorsement |
| Assurance planning      | Evidence architecture discussion                                               | Assurance criteria, independence, evidence     | AARM L4/L5 boundary                        | No assurance opinion    |



|          |                 |                    |                |          |
|----------|-----------------|--------------------|----------------|----------|
| Use case | WP2 can support | WP2 cannot replace | Useful objects | Boundary |
|----------|-----------------|--------------------|----------------|----------|

evaluation, opinion

**Table note:** Professional-use matrix is author synthesis grounded in assurance and AI audit practice sources. It is not a firm methodology, engagement template, or endorsement claim.

Cross-Links

- Chapter 1 defines scope and boundary.
- Chapter 12 defines third-party validation boundaries.
- Appendix F provides safe language.

Boundary Note

This chapter does not claim that audit or assurance firms need WP2, endorse WP2, have adopted WP2, or should replace their methods with WP2.

16. Conclusion

**Candidate source status:** R4 publication-candidate preparation source **Chapter purpose:** Close the WP2 argument and bridge to Guide 1, Guide 2, and WP3 without publication or insurability overclaim. **Reader question:** What must exist before agentic assurance and insurability conversations can mature?

Key Claims

- Auditability begins when agentic lifecycle work becomes reconstructable.
- Logs record activity; evidence chains support responsibility review.
- WP2 prepares the path for Guide 1, Guide 2, and later WP3.

Source Grounding Note

Audit evidence and assurance boundary language uses AUD-01 and AUD-03. AI governance context uses AI-01. GAIC source truth supports the WP1/WP2/WP3 object-chain relationship and companion-paper boundary.

## **Author Synthesis Note**

The Compliance Object -> Audit Evidence Object -> Insurable Risk Object chain is GAIC/WP2 author synthesis. WP3 source research is deferred.

## **Candidate Prose**

Agentic AI changes the auditability problem because agentic systems do not merely produce outputs. They perform lifecycle work. They act through roles, tools, delegated authority, handoffs, privacy boundaries, exceptions, and remediation workflows. If that work cannot be reconstructed, the system may be impressive, observable, and even well-governed in parts, but it is not audit-ready in the sense WP2 defines.

The core thesis therefore remains simple: AI agent auditability cannot be built on logs alone. Logs record activity; evidence chains support responsibility review. The difference is the lifecycle responsibility layer. A log may show that an event occurred. An Audit Evidence Chain shows how that event relates to authority, human role, agent role, tool action, evidence pointer, accepted outcome, exception, privacy treatment, and closure.

WP2's contribution is the Audit Evidence Object layer. WP1 defined the compliance object layer through Agentic Lifecycle Governance and MROs. WP2 translates that layer into evidence requests, walkthroughs, partitioning rules, privacy-aware disclosure, validation boundaries, and readiness levels. It defines Agentic AI Auditability as the ability to reconstruct, test, and evidence agentic lifecycle work across authority, responsibility, tools, outcomes, exceptions, and remediation.

The paper also sets limits. It does not issue assurance. It does not certify systems. It does not prove legal compliance. It does not bind regulators. It does not replace professional audit or assurance methodology. It does not rank vendors. It does not require MPLP. It does not make Validation Lab a certification authority.

These limits are not disclaimers at the edge of the work; they are part of the architecture. Auditability is strongest when the evidence object and the claim boundary are both explicit.

For enterprises, the next step is design. CIOs and CTOs need evidence architecture that captures lifecycle responsibility by design, not after-the-fact logs by accident. CCOs and governance leaders need policy-to-evidence operating models that turn authority, oversight, privacy, exception, and remediation policies into reviewable objects. Internal audit and risk teams need walkthrough structures that test reconstructability before assurance claims appear.

For audit and assurance firms, the next step is method dialogue. WP2 can support object-model discussions, readiness scoping, evidence request framing, and lifecycle walkthrough design. It cannot replace professional standards, engagement criteria, independence, evidence evaluation, or reporting.

For the series, WP2 completes the second layer of the 3+3 front half. WP1 established the compliance object layer. WP2 establishes the audit evidence object layer. Guide 1 will translate auditability into technical architecture. Guide 2 will translate auditability into compliance operating model. WP3 will later ask what evidence and governance structures are needed before insurable risk can be evaluated.

The object chain is:

| Series layer | Object layer                    | Question                                                                                   | Boundary                                                |
|--------------|---------------------------------|--------------------------------------------------------------------------------------------|---------------------------------------------------------|
| WP1          | Compliance Object               | What lifecycle responsibility objects does agentic governance require?                     | Not legal compliance proof                              |
| WP2          | Audit Evidence Object           | Can agentic lifecycle work be reconstructed through responsibility-linked evidence chains? | Not audit standard, certification, or assurance opinion |
| WP3          | Insurable Risk Object           | What risk evidence may later support insurability analysis?                                | Deferred; no insurance guarantee                        |
| Guide 1      | Technical implementation path   | How can systems capture audit-ready evidence by design?                                    | Future guide, not drafted here                          |
| Guide 2      | Compliance operating model path | How can governance translate policy into evidence?                                         | Future guide, not drafted here                          |

**Table note:** GAIC/WP2 author-synthesis table. It preserves companion-paper sequencing and does not claim WP3 conclusions.

Auditability begins when agentic lifecycle work becomes reconstructable. Logs record activity; evidence chains support responsibility review. WP2 prepares the path for Guide 1, Guide 2, and

later WP3 by defining the evidence object layer that must exist before agentic assurance or insurability conversations can be serious.

Cross-Links

- Appendix F preserves conclusion-safe boundary language.
- Guide 1 and Guide 2 remain future practitioner guides.
- WP3 remains a future white paper with separate source research.

Boundary Note

This chapter does not claim WP2 is published, final, sealed, regulator-approved, adopted by firms, or sufficient for assurance, certification, legal compliance, procurement, or insurance.

Appendix A — Agentic Audit Evidence Request List

**Candidate source status:** R4 publication-candidate preparation appendix **Purpose:** Provide a structured evidence request catalog for agentic systems. **Intended reader:** Audit/assurance teams, internal audit, AI governance, CIO/CTO/CCO teams, technology risk teams, and evidence architecture owners.

Source Grounding

Audit evidence and control vocabulary: AUD-01, AUD-02, AUD-04, AUD-05, AUD-06. GAIC dependencies: MRO-01 through MRO-16, Evidence-Based Validation Pattern, Validation Lab boundary.

Boundary

This appendix is an evidence request architecture. It is not a formal audit procedure, legal demand, certification criterion, procurement checklist, assurance engagement plan, or proof of legal compliance.

Evidence Request Catalog

| Request ID | Lifecycle stage | Evidence requested | Related MRO    | Owner | Privacy treatment | Boundary note  |
|------------|-----------------|--------------------|----------------|-------|-------------------|----------------|
| ER-01      | Work initiation | Work unit ID,      | MRO-08 Request |       | Record only       | Does not prove |

| Request ID | Lifecycle stage     | Evidence requested                                                                 | Related MRO | Owner                    | Privacy treatment                             | Boundary note                   |
|------------|---------------------|------------------------------------------------------------------------------------|-------------|--------------------------|-----------------------------------------------|---------------------------------|
|            |                     | task intent, request source, scope, excluded scope                                 |             | owner                    | necessary purpose/context fields              | business appropriateness        |
| ER-02      | Role mapping        | Human role for intent, authorization, review, acceptance, exception, remediation   | MRO-01      | Governance/control owner | Role data minimized to function and authority | Does not assign legal liability |
| ER-03      | Delegated authority | Authority grant, conditions, expiry, risk class, confirmation and escalation rules | MRO-02      | Delegating role          | Restrict authority evidence to review scope   | Not legal delegation proof      |
| ER-04      | Agent role          | Agent role, capability boundary, constraints, evidence duties, escalation route    | MRO-03      | Platform owner           | Avoid storing unnecessary prompt/user data    | Agent is not a human role       |
| ER-05      | Accepted            | Acceptance criteria,                                                               | MRO-04      | Review                   | Redact sensitive output fields where          | Acceptance is not compliance    |

| Request ID | Lifecycle stage         | Evidence requested                                                                             | Related MRO | Owner             | Privacy treatment                           | Boundary note                     |
|------------|-------------------------|------------------------------------------------------------------------------------------------|-------------|-------------------|---------------------------------------------|-----------------------------------|
|            | outcome                 | reviewer role, accepted/rejected/disputed/remediated state                                     |             | owner             | possible                                    | proof                             |
| ER-06      | Tool action             | Tool ID, action type, target system, affected data/process, reversibility, rollback path       | MRO-05      | Tool-action owner | Classify affected data and redact as needed | Not legal liability finding       |
| ER-07      | Responsibility transfer | Source agent, target agent, transferred scope, retained scope, inherited constraints           | MRO-06      | Process owner     | Partition by work unit and agent role       | Not legal responsibility transfer |
| ER-08      | Authority drift         | Baseline authority, observed action, drift trigger, escalation, stop/downgrade/reauthorization | MRO-07      | Escalation owner  | Limit exposure to event-relevant fields     | Not every drift is legal breach   |
| ER-09      | Evidence                | Partition keys,                                                                                | MRO-08      | Evidence          | Use scoped                                  | Not blanket                       |

| Request ID | Lifecycle stage        | Evidence requested                                                                       | Related MRO | Owner                    | Privacy treatment                        | Boundary note             |
|------------|------------------------|------------------------------------------------------------------------------------------|-------------|--------------------------|------------------------------------------|---------------------------|
|            |                        | links, evidence pointers, integrity hashes, access/disclosure rules                      |             | owner                    | access and redaction profiles            | retention                 |
| ER-10      | Cross-project reuse    | Source context, target context, reset validation, privacy review, authorization refresh  | MRO-09      | Reuse owner              | Revalidate data categories and retention | Not legal reuse clearance |
| ER-11      | Privacy lifecycle      | Data flow, processing purpose, retention rule, rights workflow, minimization treatment   | MRO-10      | Privacy owner            | Apply privacy-by-design review           | Not legal advice          |
| ER-12      | Third-party validation | Ruleset identity, evidence pointer, disclosure/redaction profile, verdict hash, reviewer | MRO-11      | Validation/ review owner | Use selective disclosure package         | Not certification         |

| Request ID | Lifecycle stage          | Evidence requested                                                                  | Related MRO | Owner                  | Privacy treatment                                   | Boundary note                 |
|------------|--------------------------|-------------------------------------------------------------------------------------|-------------|------------------------|-----------------------------------------------------|-------------------------------|
|            |                          | boundary                                                                            |             |                        |                                                     |                               |
| ER-13      | Evidence minimization    | Minimization rule, disclosure justification, redaction profile, access log, expiry  | MRO-12      | Evidence/privacy owner | Minimize and document residual exposure             | Not privacy compliance proof  |
| ER-14      | Rights vs retention      | Request type, retention basis, hold status, deletion/redaction action, review owner | MRO-13      | Privacy/legal owner    | Requires jurisdiction-specific review               | Not legal interpretation      |
| ER-15      | Processor chain          | Processor role, subprocessor chain, data processing pointer, responsibility owner   | MRO-14      | Vendor/privacy owner   | Restrict processor evidence by need-to-know         | Not vendor ranking            |
| ER-16      | Substitution conformance | Prior/new model, vendor, runtime, tool, evidence-integrity check, reauthorization   | MRO-15      | Change owner           | Preserve evidence continuity without over-retention | Not conformance certification |
| ER-17      | Incident/ remediation    | Event, affected outcome,                                                            | MRO-16      | Remediation            | Redact sensitive incident details as                | Not legal closure             |



| Request ID | Lifecycle stage | Evidence requested                           | Related MRO | Owner | Privacy treatment | Boundary note |
|------------|-----------------|----------------------------------------------|-------------|-------|-------------------|---------------|
|            |                 | owner, corrective action, closure            |             | owner | needed            |               |
|            |                 | recheck, closure acceptance, reopen criteria |             |       |                   |               |

Guide Relationship

Guide 1 should translate this appendix into system output requirements, evidence export design, runtime metadata, and workflow architecture. Guide 2 should translate it into policy-to-evidence governance, audit preparation, review cadence, and closure routines.

Placement Recommendation

Retain a condensed version in the WP2 main PDF. A fuller operational checklist can be deferred to Guide 1 and Guide 2.

Appendix B — Agentic System Walkthrough Template

**Candidate source status:** R4 publication-candidate preparation appendix **Purpose:** Provide a repeatable walkthrough structure for a single agentic lifecycle run. **Intended reader:** Internal audit, technology risk, AI governance committees, architecture review teams, platform owners, and compliance engineering teams.

Source Grounding

Control and audit practice context: AUD-04, AUD-05, AUD-06. Provenance and observability context: EVID-01, EVID-02. GAIC dependencies: MRO-01 through MRO-08 and MRO-16.

Boundary

This template is illustrative. It is not a formal audit procedure, assurance engagement program, legal compliance test, certification path, or regulator-approved walkthrough.

## Walkthrough Fields

| Field               | Description                                                    | Evidence pointer                 | Related MRO    | Boundary note                  |
|---------------------|----------------------------------------------------------------|----------------------------------|----------------|--------------------------------|
| Work unit ID        | Stable identifier for the lifecycle work under review          | Workflow/run/task record         | MRO-08         | Not mandatory schema           |
| Intent and scope    | Purpose, initiating request, in-scope and out-of-scope actions | Request record, policy reference | MRO-01, MRO-08 | Does not prove appropriateness |
| Initiator role      | Human or system role that initiated the work                   | Role map                         | MRO-01         | Not legal liability assignment |
| Delegated authority | Authority grant, conditions, expiry, confirmation, escalation  | Authority record                 | MRO-02         | Not legal delegation proof     |
| Agent role          | Agent identity, role boundary, constraints, capability limits  | Agent registry/config record     | MRO-03         | Agent role is not human role   |
| Tool/system used    | Tool, external system, API, processor, runtime                 | Tool-action evidence             | MRO-05, MRO-14 | Not vendor ranking             |
| Evidence pointers   | Logs, traces, approvals, tickets, records, hash manifests      | Evidence chain references        | MRO-08, MRO-12 | Not blanket disclosure         |
| Human review        | Reviewer role, review criteria, review result                  | Review record                    | MRO-01, MRO-04 | Not assurance opinion          |
| Accepted outcome    | Produced/accepted/rejected/disputed/remediated state           | Outcome record                   | MRO-04         | Not compliance proof           |

| Field                       | Description                                                     | Evidence pointer          | Related MRO      | Boundary note            |
|-----------------------------|-----------------------------------------------------------------|---------------------------|------------------|--------------------------|
| Exception state             | Drift, dispute, failure, privacy event, tool side effect        | Exception record          | MRO-07, MRO-16   | Not legal breach finding |
| Remediation closure         | Corrective action, recheck, closure acceptance, reopen criteria | Remediation record        | MRO-16           | Not legal settlement     |
| Privacy treatment           | Data category, redaction, retention, disclosure profile         | Privacy/disclosure record | MRO-10 to MRO-13 | Not legal advice         |
| Third-party review boundary | Reviewer role, ruleset, scope, result, limitation               | Validation/review record  | MRO-11           | Not certification        |

## Walkthrough Sequence

1. Identify the work unit and review scope.
2. Confirm the authority boundary and role ownership.
3. Reconstruct agent actions, tool actions, and handoffs.
4. Link logs/traces to evidence pointers and lifecycle objects.
5. Verify accepted outcome, dispute, or rejection state.
6. Review exceptions and remediation closure.
7. Confirm privacy/selective disclosure treatment.
8. Record what the walkthrough supports and what it does not prove.

## Guide Relationship

Guide 1 should use this template as a technical evidence export and walkthrough architecture pattern. Guide 2 should use it as an audit preparation and governance review workflow.

## Placement Recommendation

Include in the WP2 PDF if space allows. Expand implementation details in Guide 1 and governance workflow details in Guide 2.

---

# Appendix C — MRO-to-Audit-Evidence Mapping

**Candidate source status:** R4 publication-candidate preparation appendix **Purpose:** Preserve the full mapping from GAIC MROs to WP2 audit evidence objects. **Intended reader:** Audit/assurance method teams, compliance engineering, internal audit, AI governance, Guide 1/2 authors.

## Source Grounding

GAIC source truth defines MRO-01 through MRO-16. Audit evidence and control language is grounded in AUD-01, AUD-05, and AI-01. This appendix is GAIC-derived plus WP2 author synthesis.

## Boundary

MROs are proposed GAIC governance objects. They are not legal mandates, audit standards, certification criteria, procurement criteria, or legal compliance proof.

## Full Mapping

| MRO                                             | Evidence object               | Audit question                                                                   | Evidence request                                               | AARM dimension                       | Guide 1 relation                                 | Guide 2 relation                  |
|-------------------------------------------------|-------------------------------|----------------------------------------------------------------------------------|----------------------------------------------------------------|--------------------------------------|--------------------------------------------------|-----------------------------------|
| MRO-01 Human Role to MAS Responsibility Mapping | Human-role responsibility map | Who owned intent, authorization, review, acceptance, exception, and remediation? | Role map with lifecycle stage and evidence duty                | Human / agent responsibility mapping | Capture roles in workflows and evidence metadata | Define roles and account routines |
|                                                 |                               | Was the agent authorized for the action under scope and condition?               | Authority grant, expiry, risk class, escalation, reauthorizati | Authority traceability               | Implement authority checks and evidence records  | Govern delegat policy a approva   |

| MRO                                          | Evidence object                | Audit question                                                                    | Evidence request                                                        | AARM dimension                       | Guide 1 relation                                     | Guide 2 relation                   |
|----------------------------------------------|--------------------------------|-----------------------------------------------------------------------------------|-------------------------------------------------------------------------|--------------------------------------|------------------------------------------------------|------------------------------------|
|                                              |                                |                                                                                   | on                                                                      |                                      |                                                      |                                    |
| MRO-03 Agent Role is not Human Role          | Agent role boundary object     | Was the agent role separated from human accountability?                           | Agent role, constraints, owner, escalation                              | Human / agent responsibility mapping | Define agent role registry and capability boundaries | Governance role owners             |
|                                              |                                |                                                                                   | Acceptance                                                              |                                      |                                                      |                                    |
| MRO-04 Accepted Outcome Compliance           | Accepted outcome record        | Was the output accepted, rejected, disputed, or remediated?                       | criteria, reviewer, outcome state, evidence link                        | Accepted outcome evidence            | Capture outcome state transitions                    | Governance review and acceptance   |
| MRO-05 Tool-Action Liability Boundary        | Tool-action evidence object    | What tool created consequence, under what authority, and with what reversibility? | Tool, target, action, affected data, rollback, owner                    | Agent/tool partitioning              | Instrument tool-action evidence                      | Define tool action approval review |
| MRO-06 Responsibility Transfer Across Agents | Responsibility transfer record | Did responsibility transfer or remain with source role?                           | Source/ target agent, transferred/retained scope, inherited constraints | Human / agent responsibility mapping | Capture handoff records                              | Governance transfer escalation     |
| MRO-07 Authority                             | Authority drift                | Did observed                                                                      | Baseline,                                                               | Authority                            | Detect and                                           | Governance                         |

| MRO                                              | Evidence object                   | Audit question                                                | Evidence request                                                               | AARM dimension                                | Guide 1 relation                        | Guide 2 relation           |
|--------------------------------------------------|-----------------------------------|---------------------------------------------------------------|--------------------------------------------------------------------------------|-----------------------------------------------|-----------------------------------------|----------------------------|
|                                                  |                                   |                                                               | observed                                                                       |                                               |                                         |                            |
| Drift                                            | exception record                  | action exceed delegated authority?                            | action, trigger, escalation, closure                                           | traceability; exception traceability          | record drift                            | escalation                 |
| MRO-08 MAS Evidence Partitioning                 | Partitioned evidence chain        | Can evidence be separated and linked for review?              | Partition keys, links, hashes, evidence pointers, access rules                 | Evidence sufficiency; agent/tool partitioning | Build partitioned evidence architecture | Governance evidence access |
| MRO-09 Cross-Project Reuse Compliance            | Reuse context validation record   | Was reused agent/workflow context reset and revalidated?      | Source/target context, reset validation, privacy review, authorization refresh | Agent/tool partitioning                       | Implement reuse validation checks       | Governance policy          |
| MRO-10 Privacy / GDPR Lifecycle Mapping          | Privacy lifecycle evidence object | How does lifecycle work map to data processing and retention? | Data flow, purpose, retention rule, rights workflow, minimization              | Privacy and selective disclosure              | Capture privacy metadata                | Governance privacy review  |
| MRO-11 Privacy-Preserving Third-Party Validation | Validation disclosure profile and | Can third-party review happen without raw                     | Ruleset, redaction/dis closure                                                 | Third-party review boundary;                  | Support export/replay packages          | Governance party re        |

| MRO                                                      | Evidence object                             | Audit question                                              | Evidence request                                                                 | AARM dimension                    | Guide 1 relation                     | Guide 2 relation                 |
|----------------------------------------------------------|---------------------------------------------|-------------------------------------------------------------|----------------------------------------------------------------------------------|-----------------------------------|--------------------------------------|----------------------------------|
|                                                          | verdict record                              | over-disclosure?                                            | profile, evidence pointer, verdict hash                                          | privacy                           |                                      |                                  |
| MRO-12 Evidence Minimization and Selective Disclosure    | Evidence minimization and disclosure object | Is disclosed evidence limited to review purpose?            | Minimization rule, disclosure justification, redaction profile, access log       | Privacy and selective disclosure  | Build redaction/selective disclosure | Governance disclosure approval   |
| MRO-13 Data Subject Rights vs Evidence Retention         | Rights-retention reconciliation record      | How are rights requests reconciled with evidence retention? | Request, retention basis, hold status, redaction/deletion action                 | Privacy and selective disclosure  | Support retention/rights workflows   | Governance legal/practice review |
| MRO-14 Third-Party Processor / Subprocessor Chain        | Processor/subprocessor chain evidence       | Which third parties processed or affected lifecycle work?   | Processor role, subprocessor chain, data agreement pointer, responsibility owner | Agent/tool partitioning           | Capture vendor/processor evidence    | Governance process chain         |
| MRO-15 Vendor / Model / Runtime Substitution Conformance | Substitution conformance record             | Did evidence continuity survive component                   | Prior/new component, integrity check,                                            | Agent/tool partitioning; evidence | Implement substitution evidence      | Governance change review         |

| MRO                                               | Evidence object                      | Audit question                                | Evidence request                                                    | AARM dimension                              | Guide 1 relation                | Guide 2 relation               |
|---------------------------------------------------|--------------------------------------|-----------------------------------------------|---------------------------------------------------------------------|---------------------------------------------|---------------------------------|--------------------------------|
|                                                   |                                      | change?                                       | reauthorization, revalidation                                       | sufficiency                                 | controls                        |                                |
| MRO-16 Incident, Dispute, and Remediation Closure | Incident/ remediation closure record | Did exception or dispute close with evidence? | Event, affected outcome, owner, corrective action, recheck, closure | Exception traceability; remediation closure | Build closure workflow evidence | Governance remediation closure |

## Guide Relationship

Guide 1 should treat this appendix as an implementation-neutral architecture checklist. Guide 2 should treat it as a policy-to-evidence and compliance operating model checklist.

## Placement Recommendation

Include full mapping in the WP2 appendix. Consider a shorter summary table in Chapter 6.

# Appendix D — Auditability Readiness Matrix

**Candidate source status:** R4 publication-candidate preparation appendix **Purpose:** Provide AARM dimension and readiness-level crosswalk. **Intended reader:** Audit readiness teams, CIO/CTO/CCO leaders, internal audit, governance committees, platform teams.

## Source Grounding

Audit evidence: AUD-01. AI audit practice: AUD-05, AUD-06. AI governance: AI-01. Boundary: BOUND-03. GAIC dependency: R4B/R1 AARM baseline, MROs, ALCS context, Validation Lab boundary.



Boundary

AARM is not an audit standard, certification, assurance opinion, legal compliance proof, regulator approval, procurement recommendation, vendor ranking, or score.

AARM Dimensions

| Dimension                            | Definition                                      | Audit question                                                              | Evidence expected                                    | GAIC/MRO dependency    | Author-synthesis note | Bo            |
|--------------------------------------|-------------------------------------------------|-----------------------------------------------------------------------------|------------------------------------------------------|------------------------|-----------------------|---------------|
| Audit object clarity                 | System can identify lifecycle work under review | Can reviewers name the lifecycle unit, scope, object inventory and outcome? | Lifecycle ID, workflow scope, object inventory       | MRO-01, MRO-03, MRO-04 | AARM synthesis        | Not           |
| Authority traceability               | Delegated authority can be traced to action     | Was the action authorized within scope?                                     | Authority grant, expiry, escalation, reauthorization | MRO-02, MRO-07         | AARM synthesis        | Not dele      |
| Human / agent responsibility mapping | Human and agent roles are separated and mapped  | Who owned intent, execution, review, acceptance , remediation?              | Role-responsibility map, transfer record             | MRO-01, MRO-03, MRO-06 | AARM synthesis        | No ant        |
| Evidence sufficiency                 | Evidence supports reconstruction under review   | Can reviewers reconstruct without                                           | Evidence chain, pointers, integrity records          | MRO-04, MRO-08, MRO-16 | AARM synthesis        | Not suffi con |

| Dimension                 | Definition                                                 | Audit question                                                 | Evidence expected                                     | GAIC/MRO dependency            | Author-synthesis note  | Bottom line |
|---------------------------|------------------------------------------------------------|----------------------------------------------------------------|-------------------------------------------------------|--------------------------------|------------------------|-------------|
| Agent/tool partitioning   | scope                                                      | narrative memory?                                              |                                                       |                                |                        |             |
|                           |                                                            | Can reviewers identify                                         |                                                       |                                |                        |             |
|                           | Evidence separates agent, tool, vendor, processor, project | which surface produced each evidence item?                     | Agent/tool trace, partition keys, substitution record | MRO-05, MRO-08, MRO-14, MRO-15 | AARM synthesis         | No          |
| Exception traceability    | Exceptions link to lifecycle objects and owners            | Can deviation be linked to authority, impact, and next action? | Exception record, impact scope, escalation            | MRO-07, MRO-16                 | GAIC-derived synthesis | Not find    |
| Accepted outcome evidence | Outcome states are recorded with role and evidence linkage | Who accepted, rejected, disputed, or remediated the result?    | Outcome state, reviewer role, evidence link           | MRO-04                         | GAIC-derived synthesis | Acco<br>con |
| Remediation closure       | Corrective action and closure are evidence-backed          | What was remediated and who accepted                           | Remediation plan, correction evidence, recheck,       | MRO-16                         | GAIC-derived synthesis | Not sett    |

| Dimension                        | Definition                                       | Audit question                            | Evidence expected                           | GAIC/MRO dependency    | Author-synthesis note | Bo      |
|----------------------------------|--------------------------------------------------|-------------------------------------------|---------------------------------------------|------------------------|-----------------------|---------|
|                                  |                                                  | closure?                                  | closure status                              |                        |                       |         |
|                                  |                                                  | Can review                                |                                             |                        |                       |         |
| Privacy and selective disclosure | Evidence can be minimized and disclosed by scope | happen without exposing more than needed? | Redaction, retention, disclosure profile    | MRO-10 to MRO-13       | WP2 synthesis         | Not     |
| Third-party review boundary      | Review role and claim boundary are explicit      | What can reviewers inspect and not claim? | Scope, ruleset, verdict, boundary statement | MRO-11, MRO-12, MRO-16 | WP2 synthesis         | No cert |

## Readiness Levels

| Level           | Definition                                            | Observable traits                              | Minimum evidence          | What it does not prove                               | Source / synthesis classification            |
|-----------------|-------------------------------------------------------|------------------------------------------------|---------------------------|------------------------------------------------------|----------------------------------------------|
| L0 Unobservable | Lifecycle work cannot be reconstructed                | Outputs only, informal memory, no lifecycle ID | None or ad hoc notes      | Absence of risk or non-compliance                    | WP2 synthe grounded in audit eviden concepts |
| L1 Log-Visible  | Activity logs exist but are not responsibility-linked | Logs, traces, timestamps, event streams        | Raw logs or trace exports | Authority, responsibility, accepted outcome, closure | EVID-02/ EVID-03 + WP2 synthe                |
| L2 Trace-Linked | Logs/traces connect some actions to                   | Workflow IDs, agent/tool traces, partial       | Trace-linked run records  | Complete lifecycle responsibility or                 | EVID-01/ EVID-02 +                           |

| Level                  | Definition                                                                                         | Observable traits                                                       | Minimum evidence                                 | What it does not prove                                                  | Source / synthesis classification       |
|------------------------|----------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------|--------------------------------------------------|-------------------------------------------------------------------------|-----------------------------------------|
|                        | workflows or actors                                                                                | actor link                                                              |                                                  | sufficient evidence                                                     | WP2 synthesis                           |
| L3 Evidence-Structured | Lifecycle objects exist for reconstruction                                                         | Role maps, authority objects, outcome records, exception records        | MRO-aligned evidence objects                     | Assurance readiness, legal compliance, operating effectiveness          | GAIC-derived + audit/control grounding  |
| L4 Auditability-Ready  | Defined-scope evidence chains reconstruct lifecycle work                                           | Walkthroughs, evidence requests, privacy controls, closure records      | Complete evidence chain for review scope         | Audit opinion, certification, regulator approval                        | WP2 synthesis                           |
| L5 Assurance-Ready     | Evidence architecture may support professional assurance planning or review within a defined scope | Repeatable evidence packs, reviewer scope, rulesets, recheck procedures | Reviewable evidence packs and boundary statement | Actual assurance, certification, legal compliance, regulator acceptance | WP2 synthesis bounded by AUD-03/BO D-03 |

## Minimum Evidence Crosswalk

| Dimension            | L0/L1 concern  | L2/L3 transition        | L4/L5 transition          |
|----------------------|----------------|-------------------------|---------------------------|
| Audit object clarity | No stable work | Work unit IDs appear in | Work units support scoped |

| Dimension                    | L0/L1 concern                         | L2/L3 transition                 | L4/L5 transition                                                  |
|------------------------------|---------------------------------------|----------------------------------|-------------------------------------------------------------------|
|                              | unit                                  | traces and evidence objects      | walkthroughs and evidence packs                                   |
| Authority traceability       | Access logs only                      | Partial authority metadata       | Delegated authority records are reconstructable                   |
| Responsibility mapping       | User/service IDs only                 | Partial role map                 | Human/agent responsibility chain is explicit                      |
| Evidence sufficiency         | Narrative memory                      | Evidence pointers emerge         | Evidence chain supports review objective                          |
| Partitioning                 | Flattened logs                        | Partial partitions               | Agent/tool/vendor/project/privacy partitions are linked           |
| Exception traceability       | Incident tickets only                 | Exceptions linked to work units  | Exceptions include owner, action, recheck, closure                |
| Accepted outcome             | Output completion only                | Partial review records           | Accepted/rejected/disputed/remediated states are evidence-backed  |
| Remediation closure          | Closed ticket only                    | Corrective action tracked        | Closure is accepted and reopen criteria exist                     |
| Privacy/selective disclosure | Collect everything or disclose ad hoc | Redaction/retention rules appear | Selective disclosure packages support review                      |
| Third-party boundary         | No scope statement                    | Limited reviewer scope           | Ruleset, scope, verdict, and non-certifying boundary are explicit |

---

## Appendix E — Exception / Remediation Closure Checklist

**Candidate source status:** R4 publication-candidate preparation appendix **Purpose:** Define

closure evidence requirements for exceptions, disputes, and remediation. **Intended reader:** Internal audit, incident governance, compliance, risk, security, AI platform owners, remediation owners.

Source Grounding

Incident/governance context: EVID-04, AI-02. Controls and audit practice: AUD-04, AUD-05, AUD-06. GAIC dependencies: MRO-04, MRO-07, MRO-16.

Boundary

This checklist frames closure as evidence-backed governance state. It does not prove legal remedy, settlement, regulator acceptance, operational effectiveness, certification, or assurance.

Closure Checklist

| Event type              | Evidence required                                                         | Owner             | Corrective action                                   | Closure status             | Reviewer            | Reopen criteria                                    | Bou note        |
|-------------------------|---------------------------------------------------------------------------|-------------------|-----------------------------------------------------|----------------------------|---------------------|----------------------------------------------------|-----------------|
| Authority exception     | Baseline authority, observed action, trigger, work unit, evidence pointer | Escalation owner  | Stop, downgrade, reauthorize, confirm, or constrain | Open / remediated / closed | Authority reviewer  | Repeat drift, scope expansion, failed confirmation | Not breac findi |
| Responsibility gap      | Missing role owner, affected lifecycle stage, agent role, work unit       | Governance owner  | Assign owner, update role map, recheck workflow     | Open / assigned / closed   | Governance reviewer | Owner missing in later run                         | Not liabi assi  |
| Tool-action side effect | Tool call, affected                                                       | Tool-action owner | Rollback, correction,                               | Open / corrected /         | System owner        | New side effect or                                 | Not             |

| Event type                | Evidence required                                                        | Owner         | Corrective action                                       | Closure status                          | Reviewer                  | Reopen criteria                         | Bonus notes          |
|---------------------------|--------------------------------------------------------------------------|---------------|---------------------------------------------------------|-----------------------------------------|---------------------------|-----------------------------------------|----------------------|
| Outcome dispute           | system/data, reversibility, rollback evidence                            | Review owner  | disable tool, add approval                              | closed                                  | Outcome reviewer          | rollback failure                        | completed            |
|                           | Output, criteria, dispute reason, reviewer notes                         |               | Re-review, correct, reject, accept with limitation      | Open / disputed / remediated / accepted |                           | New evidence or recurring dispute       | Not settled, proceed |
|                           | Data category, disclosure path, redaction/retention record               |               | Redact, restrict, delete, hold, notify internal process | Open / contained / closed               |                           | Unauthorized exposure or rights request | Not advised          |
| Handoff failure           | Source/target agent, transferred scope, retained scope, rejection reason | Process owner | Return, reassign, clarify constraints                   | Open / reassigned / closed              | Process reviewer          | Repeated failed handoff                 | Not transferred      |
| Cross-project reuse issue | Source context, target context,                                          | Reuse owner   | Revalidate, reset, withdraw, update                     | Open / revalidated / closed             | Reuse/governance reviewer | Reuse in new context                    | Not reused, clear    |

| Event type                   | Evidence required                                                                           | Owner                | Corrective action                                          | Closure status                      | Reviewer            | Reopen criteria                                            | Bou<br>note         |
|------------------------------|---------------------------------------------------------------------------------------------|----------------------|------------------------------------------------------------|-------------------------------------|---------------------|------------------------------------------------------------|---------------------|
|                              | reuse<br>decision,<br>missing<br>reset                                                      |                      | evidence                                                   |                                     |                     |                                                            |                     |
| Substitution<br>evidence gap | Prior/new<br>component,<br>evidence<br>break,<br>regression<br>or<br>revalidation<br>status | Change<br>owner      | Reauthorize,<br>retest,<br>revalidate<br>evidence<br>chain | Open /<br>revalidated /<br>closed   | Change<br>reviewer  | Component<br>change or<br>failed<br>evidence<br>continuity | Not<br>conf<br>cert |
| Remediation<br>defect        | Prior<br>remediation,<br>failed<br>recheck,<br>affected<br>outcome                          | Remediation<br>owner | Reopen,<br>assign<br>corrective<br>action,<br>recheck      | Reopened /<br>corrected /<br>closed | Closure<br>reviewer | Failed<br>recheck or<br>recurring<br>exception             | Not<br>clos         |

### Closure Evidence Fields

- Event ID.
- Work unit ID.
- Affected MRO.
- Affected outcome.
- Owner.
- Evidence pointer.
- Corrective action.
- Recheck evidence.
- Closure reviewer.
- Closure status.
- Reopen criteria.



- Privacy treatment.
- Boundary statement.

## Guide Relationship

Guide 1 should translate closure fields into workflow, ticketing, runtime, and evidence-export architecture. Guide 2 should translate closure fields into incident/dispute/remediation governance routines.

---

## Appendix F — Boundary Language

**Candidate source status:** R4 publication-candidate preparation appendix **Purpose:** Provide safe language for auditability, assurance, validation, MRO, AARM, MPLP, privacy, and professional-use boundaries. **Intended reader:** Author, editors, reviewers, publication QA, Guide 1/2 teams, source QA.

### Source Grounding

Assurance and attestation boundary: AUD-03, BOUND-03. Conformity/certification boundary: BOUND-01, BOUND-02. GAIC dependencies: Validation Lab boundary, MPLP boundary, companion-paper boundary, R4A/R4B/R4C boundary QA.

### Allowed / Forbidden / Replacement Language

| Claim area   | Allowed wording                                                                                                 | Forbidden wording                                        | Safe replacement                                                             |
|--------------|-----------------------------------------------------------------------------------------------------------------|----------------------------------------------------------|------------------------------------------------------------------------------|
| WP2 status   | "publication-candidate preparation source";<br>"internal candidate package"; "source-grounded candidate source" | "published"; "final";<br>"sealed"; "live public release" | "R4 publication-candidate preparation package, not public/final/sealed/live" |
| Auditability | "proposed auditability framework"; "lifecycle evidence guide"                                                   | "audit standard"; "official audit methodology"           | "auditability readiness framework"                                           |
| Evidence     | "evidence chain supports                                                                                        | "evidence chain proves                                   | "evidence chain supports                                                     |

| Claim area                       | Allowed wording                                                | Forbidden wording                                                | Safe replacement                                                  |
|----------------------------------|----------------------------------------------------------------|------------------------------------------------------------------|-------------------------------------------------------------------|
|                                  | reconstruction"                                                | compliance"                                                      | responsibility review"                                            |
| Agentic Audit Object             | "proposed WP2 object model"                                    | "required schema";<br>"legal category"                           | "conceptual review object"                                        |
| MRO                              | "GAIC-derived governance object"                               | "legal requirement";<br>"regulator-mandated object"              | "proposed lifecycle responsibility object"                        |
| AARM                             | "proposed readiness model"                                     | "certification level";<br>"maturity score";<br>"assurance grade" | "readiness vocabulary"                                            |
| Assurance                        | "may support assurance planning subject to professional scope" | "assures"; "guarantees assurance"; "issues assurance opinion"    | "may support readiness discussion"                                |
| Certification                    | "non-certifying review"; "not certification"                   | "certified"; "certifies systems"; "certification-ready"          | "reviewable under defined scope"                                  |
| Legal/privacy                    | "privacy/legal context";<br>"requires legal review"            | "GDPR compliant";<br>"legal compliance proof";<br>"legal advice" | "privacy-aware evidence architecture"                             |
| Big Four                         | "reviewed sources create market context"                       | "Big Four endorse WP2"; "Big Four need WP2"                      | "Big Four sources discuss related AI assurance/governance topics" |
| Audit/<br>professional<br>bodies | "supports terminology or boundary"                             | "endorses WP2";<br>"adopts AARM"                                 | "provides external professional-language context"                 |
| Validation                       | "non-certifying evidence"                                      | "certification authority";                                       | "one optional example of                                          |

| Claim area   | Allowed wording                                                                      | Forbidden wording                                          | Safe replacement                                                            |
|--------------|--------------------------------------------------------------------------------------|------------------------------------------------------------|-----------------------------------------------------------------------------|
| Lab          | adjudication example"                                                                | "proves compliance";<br>"regulator-approved"               | evidence review<br>boundary"                                                |
| MPLP         | "one optional protocol path"                                                         | "required"; "industry<br>standard"; "only correct<br>path" | "one possible<br>implementation path"                                       |
| Cognitive OS | "possible runtime path for<br>evidence capture in related<br>product-stack planning" | "required for auditability"                                | "one possible<br>implementation<br>environment, outside<br>WP2 requirement" |
| SoloCrew     | "product proof path for<br>workflow patterns in<br>planning notes"                   | "proves enterprise<br>readiness"                           | "illustrative product proof<br>path, not an enterprise-<br>readiness claim" |
| SEO/GEO      | "future planning note"                                                               | "uplift achieved";<br>"answer-engine<br>recognized"        | "future publication/visibility<br>work after artifact exists"               |
| Procurement  | "readiness conversation<br>input"                                                    | "recommended vendor";<br>"procurement ranking"             | "non-procurement<br>framework"                                              |
| WP3          | "future insurability paper"                                                          | "insurance guarantee";<br>"underwriting standard"          | "future source research<br>required"                                        |

## Big Four Boundary

Use:

- "The reviewed Big Four sources discuss AI assurance, trusted AI, governance, risk, controls, audit transformation, and agentic AI adoption."
- "These sources create market context for WP2."

Do not use:

- "Big Four firms endorse WP2."

- "The Big Four need WP2."
- "WP2 replaces Big Four methodology."

### **Audit / Professional Body Boundary**

Use professional sources for terminology and boundary. Do not imply that PCAOB, IAASB, AICPA, ISACA, IIA, ISO, NIST, OECD, EU institutions, Singapore agencies, ICO, or any other organization endorses or adopts WP2.

### **Legal / Privacy Boundary**

Use privacy and legal sources as context. State that jurisdiction-specific interpretation belongs to qualified legal/privacy professionals. Do not say any WP2 evidence object proves GDPR, EU AI Act, UK GDPR, or other legal compliance.

### **Validation Lab Boundary**

Validation Lab may be described only as one non-certifying evidence adjudication example. It does not certify systems, issue compliance certificates, provide legal opinions, issue assurance opinions, act as regulator, act as conformity assessment body, prove enterprise readiness, or guarantee insurability.

### **MPLP Boundary**

MPLP may be discussed only as one optional protocol path. WP2 does not require MPLP, does not claim MPLP is industry-standard, and does not claim MPLP proves compliance, auditability, assurance, or enterprise readiness.

### **AARM Boundary**

AARM is a proposed readiness model. It does not score vendors, certify systems, issue assurance, prove legal compliance, bind regulators, or provide procurement guidance. L5 "Assurance-Ready" means evidence architecture may support qualified assurance planning or review within a defined scope, subject to professional scope and judgment. It does not mean assurance has been issued.

---

## **Source Note and Citation Register**

R4 uses source-ID citation notes rather than public footnotes. Source IDs appear in chapter

source notes and table source-support columns. The candidate package keeps the full source register in `sources/wp2-r4-source-register.md` and the chapter-level citation map in `sources/wp2-r4-citation-map.md`.

## **R4 Citation Style Decision**

- Internal style for R4: source IDs in text and tables, plus a package-level source register.
- Public style for a later wave: decide whether to convert source IDs into endnotes, footnotes, or an appendix source register.
- Quote guidance: paraphrase by default; avoid direct quotation unless a later citation QA wave approves a short, necessary excerpt.
- Boundary guidance: source presence does not imply endorsement, standard-setting, certification, assurance, legal advice, procurement approval, or regulator approval.

## **Source Role Summary**

- BF sources: market context only.
- AUD sources: audit/assurance terminology and boundary context.
- AI sources: governance context, not legal compliance proof.
- EVID sources: observability, provenance, logs, and evidence-chain distinction.
- PRIV sources: minimization, retention, selective disclosure, and privacy/evidence tension.
- BOUND sources: validation, verification, attestation, certification, and conformity-assessment boundaries.
- GAIC-SOURCE: MROs, RCCS-M/ALCS context, Validation Lab boundary, and companion-paper sequencing.

---

## **Artifact Integrity Note**

R4 generated an internal candidate source package and checksum file. Candidate HTML/PDF/DOCX artifacts were intentionally deferred because the existing renderer scripts are GAIC WP1 specific and direct reuse would risk touching public/sealed GAIC artifact assumptions. Artifact generation is documented in `generation/wp2-r4-generation-plan.md` and the R4 artifact-generation decision report.

---

# Package Source Register

## WP2-R4 Source Register

**Status:** R4 publication-candidate preparation source register **Boundary:** Sources listed here are used for context, terminology, grounding, or boundary discipline. Inclusion does not imply endorsement of WP2, GAIC, MPLP, AARM, Validation Lab, or Jearon Wong.

### Source Use Rules

- Big Four sources are market context only.
- Audit/professional sources support audit evidence, assurance, controls, internal audit, and boundary language.
- AI governance/public guidance sources support governance context, risk management, accountability, documentation, monitoring, and human oversight.
- Evidence/provenance/observability/logging sources support the distinction between logs/traces and responsibility-linked audit evidence chains.
- Privacy sources support minimization, retention, selective disclosure, and evidence/privacy tension.
- Boundary sources support distinctions among validation, assurance, attestation, certification, conformity assessment, and audit opinion.
- GAIC source truth supports MROs, RCCS-M/ALCS context, Evidence-Based Validation Pattern, Validation Lab boundary, and companion-paper boundary.

### Register

| Source ID | Title                                      | Organization | Source class               | Use role                                             | Chapters used |
|-----------|--------------------------------------------|--------------|----------------------------|------------------------------------------------------|---------------|
| BF-01     | AI agents:<br>Scaling faster than expected | Deloitte     | Big Four<br>market context | Agentic AI adoption and enterprise readiness context | 0, 2, 14, 15  |
| BF-02     | Assurance for AI PwC                       |              | Big Four                   | AI assurance market                                  | 0, 1, 14,     |

| Source ID | Title                                                                                                    | Organization | Source class            | Use role                                                           | Chapters used            |
|-----------|----------------------------------------------------------------------------------------------------------|--------------|-------------------------|--------------------------------------------------------------------|--------------------------|
|           |                                                                                                          |              | market context          | context                                                            | 15                       |
| BF-03     | EY Assurance releases new technology capabilities strengthening confidence and trust                     | EY           | Big Four market context | Audit transformation and assurance technology context              | 1, 15                    |
| BF-04     | KPMG Trusted AI                                                                                          | KPMG         | Big Four market context | Trusted AI, governance, privacy, and accountability context        | 2, 10, 14                |
| BF-05     | AI Agents Move Beyond Experimentation as Leaders Prepare for Competitive Transformation Within 24 Months | KPMG         | Big Four market context | Agentic AI adoption and risk context                               | 0, 2, 14, 15             |
| AUD-01    | AS 1105: Audit Evidence                                                                                  | PCAOB        | Audit/professional body | Audit evidence terminology and sufficiency/appropriateness framing | 0, 3, 4, 5, 6, 7, 13, 16 |
| AUD-02    | ISA 500                                                                                                  | IAASB        | Audit/                  | Audit evidence and                                                 | 3, 4, 7, 13              |

| Source ID | Title                                                                                             | Organization | Source class                | Use role                                                             | Chapters used           |
|-----------|---------------------------------------------------------------------------------------------------|--------------|-----------------------------|----------------------------------------------------------------------|-------------------------|
|           | (Revised), Audit Evidence                                                                         |              | professional body           | technology-enabled evidence context                                  |                         |
| AUD-03    | ISAE 3000 (Revised)                                                                               | IAASB        | Audit/<br>professional body | Assurance engagement boundary                                        | 1, 12, 13, 15, 16       |
| AUD-04    | Trust Services Criteria                                                                           | AICPA        | Audit/<br>professional body | Control vocabulary, monitoring, privacy/security, control activities | 5, 7, 8, 10, 11, 14     |
| AUD-05    | Audit and Assurance Guidance for the NIST Cybersecurity Framework 2.0 and Artificial Intelligence | ISACA        | Audit/<br>professional body | AI audit and assurance practice context                              | 6, 7, 8, 11, 13, 15     |
| AUD-06    | Global Technology Audit Guide: Auditing Artificial Intelligence                                   | IIA          | Audit/<br>professional body | Internal audit, AI governance, controls, human oversight             | 2, 7, 8, 11, 13, 14, 15 |
| AUD-07    | The IIA's Three Lines Model                                                                       | IIA          | Audit/<br>professional body | Governance role separation                                           | 1, 14, 15               |
| AI-01     | Artificial                                                                                        | NIST         | Regulator/                  | AI risk management,                                                  | 0, 2, 3, 5,             |



| Source ID | Title                                                 | Organization                | Source class              | Use role                                                       | Chapters used  |
|-----------|-------------------------------------------------------|-----------------------------|---------------------------|----------------------------------------------------------------|----------------|
| AI-02     | Intelligence Risk Management Framework 1.0            | NIST                        | public guidance           | governance, monitoring, accountability                         | 6, 13, 14, 16  |
|           | NIST AI 600-1 Generative AI Profile                   |                             | Regulator/public guidance | Generative AI risk, incidents, monitoring, documentation       | 2, 7, 11, 14   |
|           | OECD AI Principles                                    |                             | Public guidance           | Responsible AI accountability and transparency context         | 1, 2, 14       |
| AI-04     | ISO/IEC 42001:2023 AI management system               | ISO                         | Standards body            | AI management-system context                                   | 2, 13, 14      |
| AI-05     | ISO/IEC 23894:2023 AI risk management                 | ISO                         | Standards body            | AI risk-management context                                     | 2, 13, 14      |
| AI-06     | Regulation (EU) 2024/1689 Artificial Intelligence Act | European Union              | Regulator/public guidance | AI governance, logging, human oversight, documentation context | 1, 2, 4, 7, 14 |
| AI-07     | Model AI Governance Framework for Generative AI       | AI Verify Foundation / IMDA | Public guidance           | Generative AI governance and testing context                   | 1, 2, 7, 14    |
| AI-08     | Model AI                                              | Singapore                   | Public                    | Agentic AI governance,                                         | 0, 2, 3, 5,    |

| Source ID | Title                                               | Organization                | Source class              | Use role                                                                           | Chapters used     |
|-----------|-----------------------------------------------------|-----------------------------|---------------------------|------------------------------------------------------------------------------------|-------------------|
|           | Governance Framework for Agentic AI                 | MDDI / AI Verify Foundation | guidance                  | autonomy, accountability, safeguards                                               | 6, 14             |
|           | Guidance on AI and Data Protection                  | UK ICO                      |                           | AI/privacy context                                                                 |                   |
| AI-09     |                                                     |                             | Regulator/public guidance |                                                                                    | 9, 10, 14         |
| EVID-01   | PROV Overview                                       | W3C                         | Technical documentation   | Provenance vocabulary for entities, activities, agents, derivation, responsibility | 3, 4, 5, 8, 9, 13 |
| EVID-02   | OpenTelemetry Observability Primer                  | OpenTelemetry               | Technical documentation   | Logs, metrics, traces, observability context                                       | 0, 4, 8, 9, 14    |
| EVID-03   | SP 800-92 Guide to Computer Security Log Management | NIST                        | Public guidance           | Log management context                                                             | 4, 9, 10          |
| EVID-04   | Cybersecurity Framework 2.0                         | NIST                        | Public guidance           | Governance, detection, response, recovery, incident context                        | 4, 11, 14         |
| PRIV-01   | GDPR Article 5                                      | European Union              | Regulator/public guidance | Minimization, storage limitation, accountability context                           | 9, 10             |
| PRIV-02   | EDPB                                                | EDPB                        | Regulator/                | Data protection by                                                                 | 9, 10             |

| Source ID   | Title                                      | Organization              | Source class                  | Use role                                       | Chapters used          |
|-------------|--------------------------------------------|---------------------------|-------------------------------|------------------------------------------------|------------------------|
|             | Guidelines 4/2019 on Article 25            |                           | public guidance               | design/default and minimization context        |                        |
| PRIV-03     | NIST Privacy Framework 1.0                 | NIST                      | Public guidance               | Privacy risk management and governance context | 10, 14                 |
| PRIV-04     | Data minimisation                          | UK ICO                    | Regulator/<br>public guidance | Data minimization context                      | 10                     |
| PRIV-05     | Storage limitation                         | UK ICO                    | Regulator/<br>public guidance | Retention and storage limitation context       | 10                     |
| BOUND-01    | CASCO - Committee on conformity assessment | ISO                       | Standards body                | Conformity-assessment boundary                 | 12, 13                 |
| BOUND-02    | ISO/IEC 17029:2019 summary                 | ISO                       | Standards body                | Validation/verification body boundary          | 12, 13                 |
| BOUND-03    | Attestation standards                      | AICPA                     | Audit/<br>professional body   | Attestation and practitioner-report boundary   | 12, 13, 15             |
| GAIC-SOURCE | GAIC v0.3.2-FRC-R3 source                  | Jearon Wong / GAIC source | GAIC-derived                  | MROs, RCCS-M/ALCS context, Evidence-           | 1, 3, 5, 6, 9, 10, 11, |

| Source ID | Title | Organization | Source class | Use role                                                                    | Chapters used          |
|-----------|-------|--------------|--------------|-----------------------------------------------------------------------------|------------------------|
|           | truth | master       | source truth | Based Validation Pattern, Validation Lab boundary, companion-paper boundary | 12, 13, 16; appendices |

## R4 Source Register Result

**PASS** - all sources used in the R4 candidate source are drawn from the WP2-R0 inventory or GAIC source truth.

## R4 Citation Style

R4 uses source IDs in text, tables, and source notes with this register as the package-level lookup. Public endnote or footnote formatting remains a later publication-candidate QA decision.

# Package Citation Map

## WP2-R4 Citation Map

**Status:** R4 publication-candidate preparation citation map **Boundary:** This map supports R4 candidate source review. It does not create final citation formatting, quote source text, or claim endorsement by any source organization.

## Chapter Citation Map

| Chapter     | Source IDs used | Source role          | Use placement | Citation risk | R4 review note |
|-------------|-----------------|----------------------|---------------|---------------|----------------|
| 0 Executive | BF-01, BF-02,   | Market context; Main |               | Big Four      | Keep Big Four  |

| Chapter                            | Source IDs used                                                         | Source role                                                           | Use placement                    | Citation risk                                       | R4 review note                                   |
|------------------------------------|-------------------------------------------------------------------------|-----------------------------------------------------------------------|----------------------------------|-----------------------------------------------------|--------------------------------------------------|
| Summary                            | BF-05, AUD-01, AI-01, EVID-02, GAIC-SOURCE                              | audit evidence;<br>governance;<br>observability;<br>GAIC source truth | argument and source note         | endorsement overclaim                               | as context only.                                 |
| 1 Scope, Audience, Boundary        | AUD-03, BOUND-01, BOUND-02, BOUND-03, AUD-07, BF-02, BF-03, GAIC-SOURCE | Boundary, audience, assurance/attestation context                     | Boundary section and table notes | Treating boundary sources as endorsement            | Repeat non-standard and non-certifying boundary. |
| 2 Difference from Model Governance | BF-01, BF-04, BF-05, AI-01, AI-02, AI-04, AI-05, AI-08, AUD-06          | Market and AI governance context                                      | Main text and Table 1            | Dismissing model governance                         | Maintain "necessary but insufficient" framing.   |
| 3 Audit Object Shift               | AUD-01, AUD-02, AI-01, AI-08, EVID-01, GAIC-SOURCE                      | Audit evidence, governance, provenance, GAIC MROs                     | Main text                        | Treating Agentic Audit Object as externally sourced | Label as WP2 author synthesis.                   |
| 4 Logs vs Evidence Chains          | AUD-01, AUD-02, EVID-01, EVID-02, EVID-03, EVID-04, AI-06               | Audit evidence, observability, logging, incident/governance context   | Main text and Table 2            | Saying logs are useless                             | State logs are useful evidence ingredients.      |
| 5 Agentic Audit Object             | AUD-01, AUD-04, AI-01, EVID-01,                                         | Evidence, controls,                                                   | Main text and object             | Mandatory schema                                    | Keep model as proposed                           |

| Chapter                     | Source IDs used                                                          | Source role                                      | Use placement         | Citation risk                              | R4 review note                                |
|-----------------------------|--------------------------------------------------------------------------|--------------------------------------------------|-----------------------|--------------------------------------------|-----------------------------------------------|
| Model                       | GAIC-SOURCE                                                              | governance, provenance, GAIC objects             | table                 | overclaim                                  | architecture.                                 |
| 6 MRO Mapping               | GAIC-SOURCE, AUD-01, AUD-05, AI-01                                       | GAIC MRO source truth; evidence/control language | Main text and Table 3 | MRO legal mandate overclaim                | Keep MROs as GAIC-derived governance objects. |
| 7 Evidence Request List     | AUD-01, AUD-02, AUD-04, AUD-05, AUD-06, AI-06                            | Audit evidence, controls, AI audit practice      | Main text and Table 4 | Evidence request as formal audit procedure | Mark as readiness/evidence architecture.      |
| 8 Lifecycle Walkthrough     | AUD-04, AUD-05, AUD-06, EVID-01, EVID-02, GAIC-SOURCE                    | Controls, audit practice, provenance, traces     | Main text and Table 5 | Formal audit procedure implication         | Keep walkthrough illustrative.                |
| 9 Evidence Partitioning     | EVID-01, EVID-02, EVID-03, PRIV-01, PRIV-02, PRIV-03, AI-09, GAIC-SOURCE | Provenance/logging/privacy/context partitioning  | Main text and Table 6 | Universal disclosure or retention          | Stress scope, access, and minimization.       |
| 10 Privacy and Minimization | PRIV-01, PRIV-02, PRIV-03, PRIV-04, PRIV-05, AI-09, GAIC-SOURCE          | Privacy and retention context                    | Main text and Table 7 | Legal advice or GDPR proof                 | Require legal/privacy review in R3.           |

| Chapter                            | Source IDs used                                           | Source role                                                                      | Use placement          | Citation risk                                   | R4 review note                                   |
|------------------------------------|-----------------------------------------------------------|----------------------------------------------------------------------------------|------------------------|-------------------------------------------------|--------------------------------------------------|
| 11 Exception and Closure           | EVID-04, AI-02, AUD-04, AUD-05, AUD-06, GAIC-SOURCE       | Incident, control, remediation, audit practice                                   | Main text and Table 10 | Legal remedy/settlement overclaim               | Closure is evidence state only.                  |
| 12 Third-Party Validation Boundary | AUD-03, BOUND-01, BOUND-02, BOUND-03, GAIC-SOURCE         | Assurance, attestation, conformity, validation boundary                          | Main text and Table 8  | Certification or assurance opinion overclaim    | Review every Validation Lab paragraph.           |
| 13 AARM                            | AUD-01, AUD-05, AUD-06, AI-01, BOUND-03, GAIC-SOURCE      | Evidence, AI audit practice, governance, attestation boundary, AARM source truth | Main text and Table 9  | Maturity/certification overclaim                | Keep "what it does not prove" column.            |
| 14 Enterprise Readiness            | BF-02, BF-04, AUD-04, AUD-07, AI-01, PRIV-03, GAIC-SOURCE | Enterprise governance, controls, three lines, privacy, market context            | Main text              | Procurement/readiness guarantee                 | Bridge only to Guide 1/Guide 2.                  |
| 15 Audit and Assurance Firm Use    | BF-02, BF-03, AUD-03, AUD-05, AUD-06, BOUND-03            | Market context, professional practice, assurance/attestation boundary            | Main text              | Big Four endorsement or methodology replacement | Use "may use as discussion/readiness structure." |
| 16                                 | GAIC-SOURCE,                                              | Object chain,                                                                    | Main text              | Insurability                                    | Keep WP3                                         |

| Chapter    | Source IDs used       | Source role                                            | Use placement | Citation risk        | R4 review note     |
|------------|-----------------------|--------------------------------------------------------|---------------|----------------------|--------------------|
| Conclusion | AUD-01, AUD-03, AI-01 | audit evidence, assurance boundary, governance context |               | overclaim before WP3 | bridge high level. |

## Appendix Citation Map

| Appendix                | Source IDs used                                       | Source role                                      | Citation risk                          | R4 review note                               |
|-------------------------|-------------------------------------------------------|--------------------------------------------------|----------------------------------------|----------------------------------------------|
| A Evidence Request List | AUD-01, AUD-02, AUD-04, AUD-05, AUD-06, GAIC-SOURCE   | Evidence/control vocabulary and MRO mapping      | Formal audit-procedure implication     | Keep request list as readiness architecture. |
| B Walkthrough Template  | AUD-04, AUD-05, AUD-06, EVID-01, EVID-02, GAIC-SOURCE | Controls, provenance, traces, MRO lifecycle      | Audit procedure implication            | Keep illustrative.                           |
| C MRO Mapping           | GAIC-SOURCE, AUD-01, AUD-05, AI-01                    | GAIC MRO source truth and audit/control language | Legal mandate overclaim                | Verify MRO names exactly.                    |
| D Readiness Matrix      | AUD-01, AUD-05, AUD-06, AI-01, BOUND-03, GAIC-SOURCE  | Evidence, audit practice, governance, boundary   | Certification/maturity-score overclaim | Keep no scores.                              |



| Appendix            | Source IDs used                                     | Source role                                                                     | Citation risk                                        | R4 review note                     |
|---------------------|-----------------------------------------------------|---------------------------------------------------------------------------------|------------------------------------------------------|------------------------------------|
| E Closure Checklist | EVID-04, AI-02, AUD-04, AUD-05, AUD-06, GAIC-SOURCE | Incident, control, remediation, MRO closure                                     | Legal closure overclaim                              | Closure means evidence state only. |
| F Boundary Language | AUD-03, BOUND-01, BOUND-02, BOUND-03, GAIC-SOURCE   | Assurance, conformity, attestation, Validation Lab and companion-paper boundary | Boundary wording becoming legal disclaimer overreach | Keep as editorial guardrail.       |

---

## R4 Citation Map Result

**PASS - R4 candidate source uses R0 source IDs and GAIC source truth with explicit source-role and citation-risk notes.**